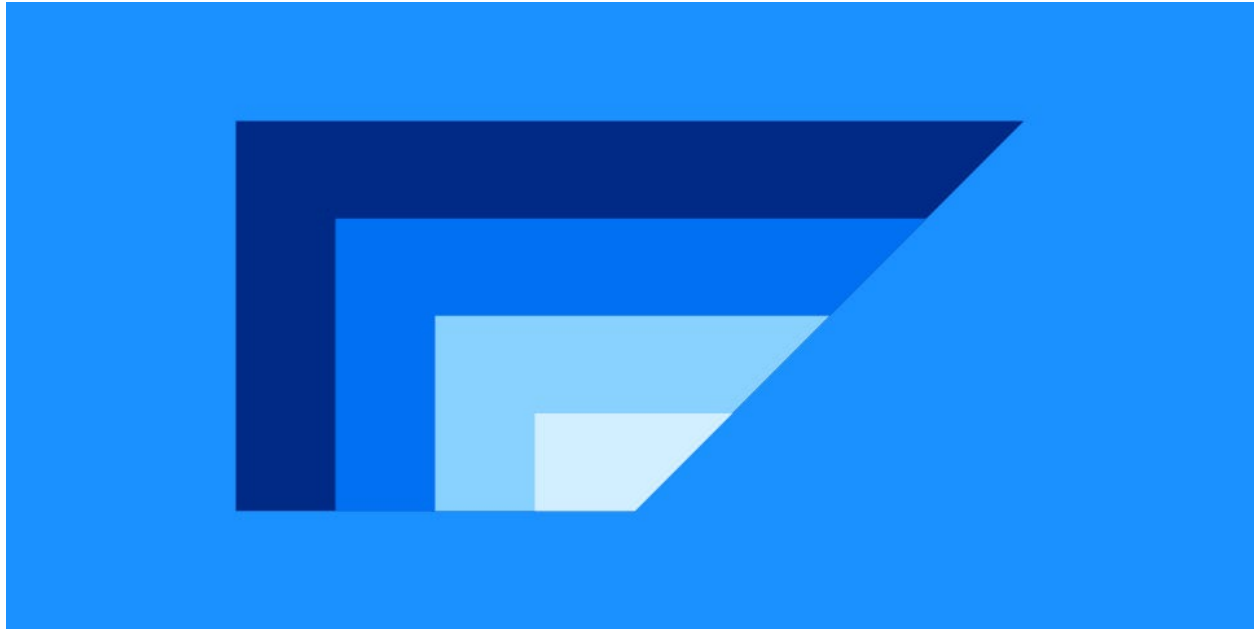


Disclaimer

If you are an SAP customer of the Cloud Services, partner for the Cloud Services, reseller of the Cloud Services, or other complementary service provider for the Cloud Services, you may distribute this document solely to user entities with whom you have agreements in relation to the Cloud Services (Downstream User Entities). By written agreement, such Downstream User Entities must agree to be responsible for the expertise needed to adequately assess such opinions distinct from or as complemented by additional services or products used with the Cloud Services, including but not limited to those elements provided by SAP's partners, consultants, or business process outsourcing firms.

Further, the information contained in the document is confidential and proprietary to SAP and must be treated in accordance with the standard of care specified in the services agreement. The document is restricted and intended only to satisfy the needs of SAP user entities both direct and indirect. Except as explicitly stated above, you are not to disclose the document or provide a copy of it to any third party without written consent of SAP, except you may provide a copy to your independent auditors or regulators solely in connection with their examinations of services performed by SAP. You may also grant the same distribution rights to independent auditors for Downstream User Entities in your written agreements with such Downstream User Entities.



System and Organization Controls (SOC) 1 Type 2

Report on Management of SAP SE's Description of Its SAP Ariba
and SAP Business Network System and on the Suitability of the
Design and Operating Effectiveness of Controls

Throughout the Period
April 1, 2024 to September 30, 2024

Report prepared pursuant to AT-C Section 320 and
International Standard on Assurance Engagements No. 3402

I.	Independent Service Auditor’s Report on a SOC 1 Examination	4
II.	Management of SAP SE’s Assertion.....	9
III.	Management of SAP SE’s Description of Its SAP Ariba and SAP Business Network System	12
IV.	SAP SE’s Description of Its Control Objectives and Related Controls, and Independent Service Auditor’s Tests of Controls and Results of Tests.....	46
V.	Other Information Provided by SAP SE That Is Not Covered by the Independent Service Auditor’s Report on a SOC 1 Examination	65

**I. Independent Service Auditor's Report
on a SOC 1 Examination**

Independent Service Auditor's Report on a SOC 1 Examination

To the Management of
SAP SE
Walldorf, Germany

Scope

We have examined SAP SE's (SAP or service organization) accompanying description of its SAP Ariba and SAP Business Network System (the System) titled *Management of SAP SE's Description of Its SAP Ariba and SAP Business Network System* for processing user entities' transactions throughout the period April 1, 2024 to September 30, 2024 (description) and the suitability of the design and operating effectiveness of controls included in the description to achieve the related control objectives stated in the description, based on the criteria identified in *Management of SAP SE's Assertion* (assertion). The controls and control objectives included in the description are those that management of SAP believes are likely to be relevant to user entities' internal control over financial reporting. The description does not include aspects of the System that are not likely to be relevant to user entities' internal control over financial reporting.

The information included in Section V, *Other Information Provided by SAP SE That Is Not Covered by the Independent Service Auditor's Report on a SOC 1 Examination*, is presented by management of SAP to provide additional information and is not part of SAP's description of its system made available to user entities during the period April 1, 2024 to September 30, 2024. Information included in Section V has not been subjected to the procedures applied in the examination of the description of the System and of the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description of the System, and accordingly, we express no opinion on it.

SAP uses subservice organizations to perform certain activities. A list of these subservice organizations and the activities performed is provided in Section III. The description includes only the control objectives and related controls of SAP and excludes the control objectives and related controls of the subservice organizations. The description also indicates that certain control objectives specified by SAP can be achieved only if complementary subservice organization controls assumed in the design of SAP's controls are suitably designed and operating effectively, along with the related controls at SAP. Our examination did not extend to controls of the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of SAP's controls are suitably designed and operating effectively, along with related controls at the service organization. Our examination did not extend to such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.



Service Organization's Responsibilities

In Section II, SAP has provided an assertion about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description. SAP is responsible for preparing the description and its assertion, including the completeness, accuracy, and method of presentation of the description and the assertion; providing the services covered by the description; specifying the control objectives and stating them in the description; identifying the risks that threaten the achievement of the control objectives; selecting the criteria stated in the assertion; and designing, implementing, and documenting controls that are suitably designed and operating effectively to achieve the related control objectives stated in the description.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the fairness of the presentation of the description and on the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description, based on our examination.

Our examination was conducted in accordance with attestation standards established by the AICPA and the International Standard on Assurance Engagements 3402, *Assurance Reports on Controls at a Service Organization*, issued by the International Auditing and Assurance Standards Board. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, based on the criteria in management's assertion, the description is fairly presented and the controls were suitably designed and operating effectively to achieve the related control objectives stated in the description throughout the period April 1, 2024 to September 30, 2024. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

- Performing procedures to obtain evidence about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of controls to achieve the related control objectives stated in the description, based on the criteria in management's assertion.
- Assessing the risks that the description is not fairly presented and that the controls were not suitably designed or operating effectively to achieve the related control objectives stated in the description.
- Testing the operating effectiveness of those controls that management considers necessary to provide reasonable assurance that the related control objectives stated in the description were achieved.
- Evaluating the overall presentation of the description, suitability of the control objectives stated therein, and suitability of the criteria specified by the service organization in its assertion.



Service Auditor's Independence and Quality Control

We have complied with the independence and other ethical requirements of the Code of Professional Conduct established by the AICPA.

We applied the Statements on Quality Control Standards established by the AICPA and accordingly maintain a comprehensive system of quality control.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of user entities and their auditors who audit and report on user entities' financial statements and may not, therefore, include every aspect of the System that each individual user entity may consider important in its own particular environment. Because of their nature, controls at a service organization may not prevent, or detect and correct, all misstatements in processing or reporting transactions. Also, the projection to the future of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design or operating effectiveness of controls to achieve the related control objectives, is subject to the risk that controls at a service organization may become ineffective.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section IV.

Opinion

In our opinion, in all material respects, based on the criteria described in SAP SE's assertion:

- a. The description fairly presents SAP's SAP Ariba and SAP Business Network System that was designed and implemented throughout the period April 1, 2024 to September 30, 2024.
- b. The controls related to the control objectives stated in the description were suitably designed to provide reasonable assurance that the control objectives would be achieved if the controls operated effectively throughout the period April 1, 2024 to September 30, 2024 and if the subservice organizations and user entities applied the complementary controls assumed in the design of SAP's controls throughout the period April 1, 2024 to September 30, 2024.
- c. The controls operated effectively to provide reasonable assurance that the control objectives stated in the description were achieved throughout the period April 1, 2024 to September 30, 2024 if complementary subservice organization controls and complementary user entity controls assumed in the design of SAP's controls operated effectively throughout the period April 1, 2024 to September 30, 2024.



Restricted Use

This report, including the description of tests of controls and results thereof in Section IV, is intended solely for the information and use of SAP, user entities of SAP's system during some or all of the period April 1, 2024 to September 30, 2024, and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by user entities themselves, when assessing the risks of material misstatement of user entities' financial statements.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

BDO USA, P.C.

November 25, 2024

II. Management of SAP SE's Assertion

Management of SAP SE's Assertion

We have prepared the accompanying description of SAP SE's (SAP or service organization) SAP Ariba and SAP Business Network System (the System) titled *Management of SAP SE's Description of Its SAP Ariba and SAP Business Network System* for processing user entities' transactions throughout the period April 1, 2024 to September 30, 2024 (description) for user entities of the System during some or all of the period April 1, 2024 to September 30, 2024 and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by the subservice organizations and user entities of the System themselves, when assessing the risks of material misstatement of user entities' financial statements.

SAP uses subservice organizations to perform certain activities. A list of these subservice organizations and the activities performed is provided in Section III. The description includes only the control objectives and related controls of SAP and excludes the control objectives and related controls of the subservice organizations. The description also indicates that certain control objectives specified by SAP can be achieved only if complementary subservice organization controls assumed in the design of SAP's controls are suitably designed and operating effectively, along with the related controls at SAP. The description does not extend to controls of the subservice organizations.

The description indicates that certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of SAP's controls are suitably designed and operating effectively, along with related controls at the service organization. The description does not extend to controls of the user entities.

We confirm, to the best of our knowledge and belief, that:

- a. The description fairly presents the SAP Ariba and SAP Business Network System made available to user entities of the System during some or all of the period April 1, 2024 to September 30, 2024 for processing their transactions as it relates to controls that are likely to be relevant to user entities' internal control over financial reporting. The criteria we used in making this assertion were that the description:
 - i. Presents how the System made available to user entities of the System was designed and implemented to process relevant user entity transactions, including, if applicable:
 - (1) The types of services provided, including, as appropriate, the classes of transactions processed.
 - (2) The procedures, within both automated and manual systems, by which those services are provided, including, as appropriate, procedures by which transactions are initiated, authorized, recorded, processed, corrected as necessary, and transferred to the reports, and other information prepared for user entities of the System.
 - (3) The information used in the performance of the procedures, including, if applicable, related accounting records, whether electronic or manual, and supporting information involved in initiating, authorizing, recording, processing, and reporting transactions; this includes the correction of incorrect information and how information is transferred to the reports and other information prepared for user entities.

- (4) How the System captures and addresses significant events and conditions other than transactions.
 - (5) The process used to prepare reports and other information for user entities.
 - (6) Services performed by a subservice organization, if any, including whether the inclusive method or the carve-out method has been used in relation to them.
 - (7) The specified control objectives and controls designed to achieve those objectives, including, as applicable, complementary subservice organization controls and complementary user entity controls assumed in the design of the service organization's controls.
 - (8) Other aspects of our control environment, risk assessment process, information and communications (including the related business processes), control activities, and monitoring activities that are relevant to the services provided.
- ii. Includes relevant details of changes to the service organization's system during the period covered by the description.
- iii. Does not omit or distort information relevant to the service organization's system, while acknowledging that the description is prepared to meet the common needs of a broad range of user entities of the System and their user auditors and may not, therefore, include every aspect of the System that each individual user entity of the System and its auditor may consider important in its own particular environment.
- b. The controls related to the control objectives stated in the description were suitably designed and operating effectively throughout the period April 1, 2024 to September 30, 2024 to achieve those control objectives if the subservice organizations and user entities applied the complementary controls assumed in the design of SAP's controls throughout the period April 1, 2024 to September 30, 2024. The criteria we used in making this assertion were that:
 - i. The risks that threaten the achievement of the control objectives stated in the description have been identified by management of the service organization.
 - ii. The controls identified in the description would, if operating effectively, provide reasonable assurance that those risks would not prevent the control objectives stated in the description from being achieved.
 - iii. The controls were consistently applied as designed, including whether manual controls were applied by individuals who have the appropriate competence and authority.

SAP SE

November 25, 2024

III. Management of SAP SE's Description of Its SAP Ariba and SAP Business Network System

Management of SAP SE's Description of Its SAP Ariba and SAP Business Network System

Overview

This is a System and Organization Controls (SOC) 1 Type 2 report on SAP SE's (SAP, service organization, or Company) SAP Ariba and SAP Business Network System (the System) for processing user entities' transactions throughout the period April 1, 2024 to September 30, 2024, which may be relevant to the internal control over financial reporting of user entities. The description has been prepared in accordance with the guidance issued by the AICPA, specifically, AT-C Section 320, *Reporting on an Examination of Controls at a Service Organization Relevant to User Entities' Internal Control Over Financial Reporting*, and the International Standard on Assurance Engagements 3402, *Assurance Reports on Controls at a Service Organization*, issued by the International Auditing and Assurance Standards Board.

Company Background

With a 52-year history of innovation, SAP is a market leader in enterprise application software, offering companies of all sizes and in all industries the Intelligence Enterprise solution. With more than 400,000 customers in more than 180 countries, the SAP Group employs more than 105,000 staff in over 140 countries. SAP's end-to-end suite of applications and services enables customers to operate profitably and continuously adapt.

Services Provided

SAP Ariba and SAP Business Network solutions enable customers to source, contract, procure, pay, manage, and analyze spend and supplier relationships. Customers use the applications to control spending and drive continuous improvements in financial and supply-chain performance.

SAP Ariba mainly consists of the following sub-solutions:

- *Sourcing and Contracts* – Solutions for sourcing and contracting.
- *Procurement* – Solutions for procure-to-pay and procurement content.
- *Invoice and Payment* – Solutions for invoice receipt, processing, and payment.
- *Supplier Management* – Solutions to manage supplier information, lifecycle, performance, and risk.

SAP Business Network mainly consists of the following sub-solutions:

- *SAP Business Network for Procurement* – Solutions for supply assurance, procurement efficiency, compliance, and spend transparency with a global network of suppliers.
- *SAP Business Network for Supply Chain* – Solutions for supply chain visibility.
- *SAP Business Network for Trading Partners* – Solutions to collaborate with customers virtually on bids, contracts, orders, catalogs, invoices, and payments through a single global platform.

SAP Integration Suite-managed gateway allows customers to integrate the SAP ERP and SAP S/4HANA back-end systems with trading partners and SAP Ariba Procurement and SAP Business Network solutions. Managed gateway is offered on the SAP Business Technology Platform (BTP).

References to “SAP Ariba and SAP Business Network” throughout this report refer to the line of business (LoB) within SAP.

SAP Ariba and SAP Business Network System Topology

The SAP Ariba and SAP Business Network system is offered as a public cloud, multi-tenant software as a service (SaaS). SAP Ariba and SAP Business Network hosts multiple customers on a load-balanced farm of identical instances, with each customer’s data kept logically segregated, and with configurable metadata for customers. The SAP Ariba and SAP Business Network Cloud Solutions are scalable to a large number of customers because the number of servers and instances on the back end can be increased or decreased as necessary to match demand, without requiring additional re-architecting of the application. Changes or fixes can be rolled out to thousands of tenants. In SAP Ariba’s technical terminology, the term “tenant” is rarely used; instead, “realm” is used in the context of the on-demand buyer applications, and “customer accounts” is used in reference to the SAP Business Network. SAP Ariba and SAP Business Network uses the term “tenant” to refer to the general concepts, which apply to both cases.

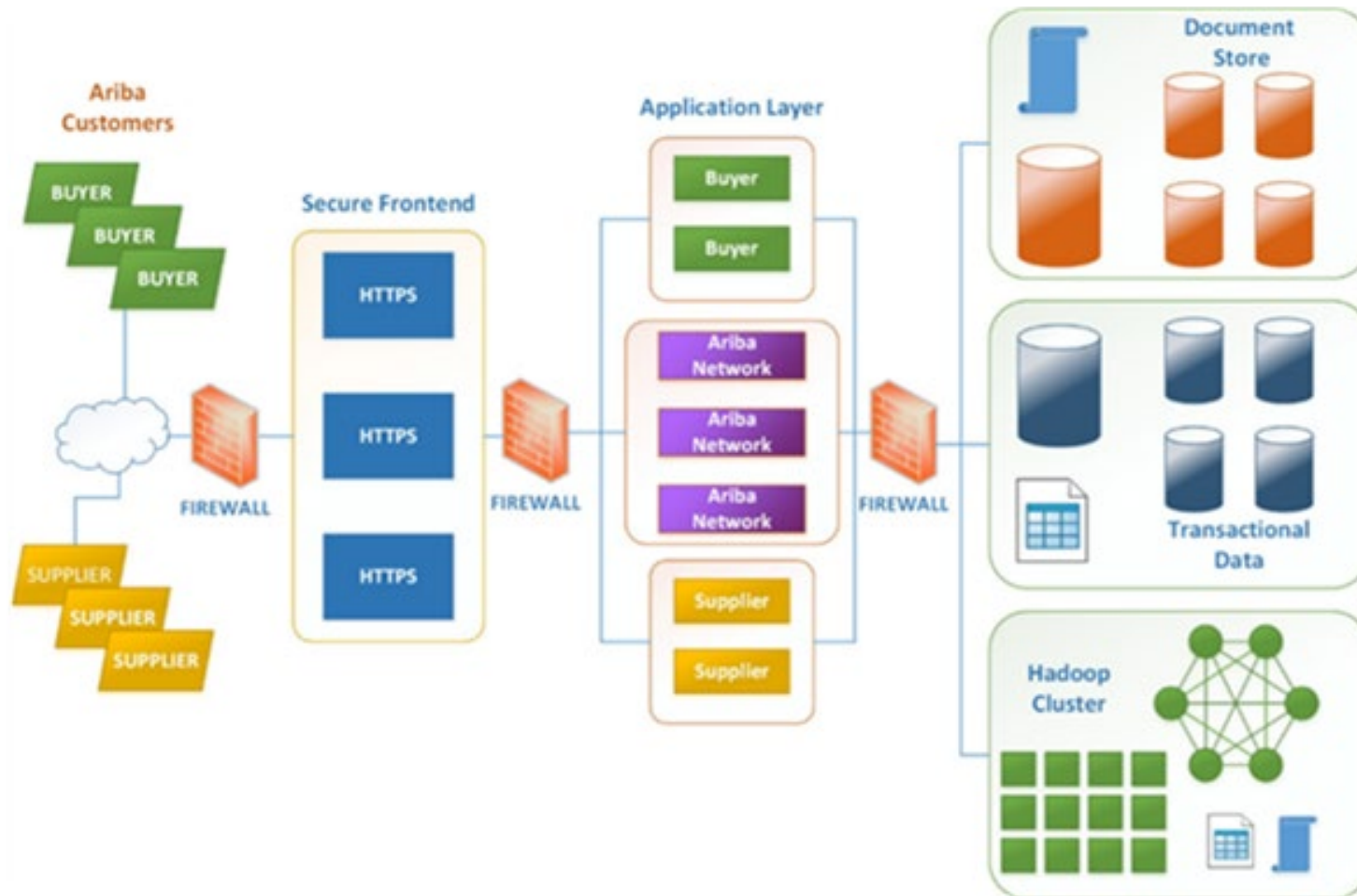
SAP Ariba and SAP Business Network System Architecture

SAP Ariba and SAP Business Network systems include:

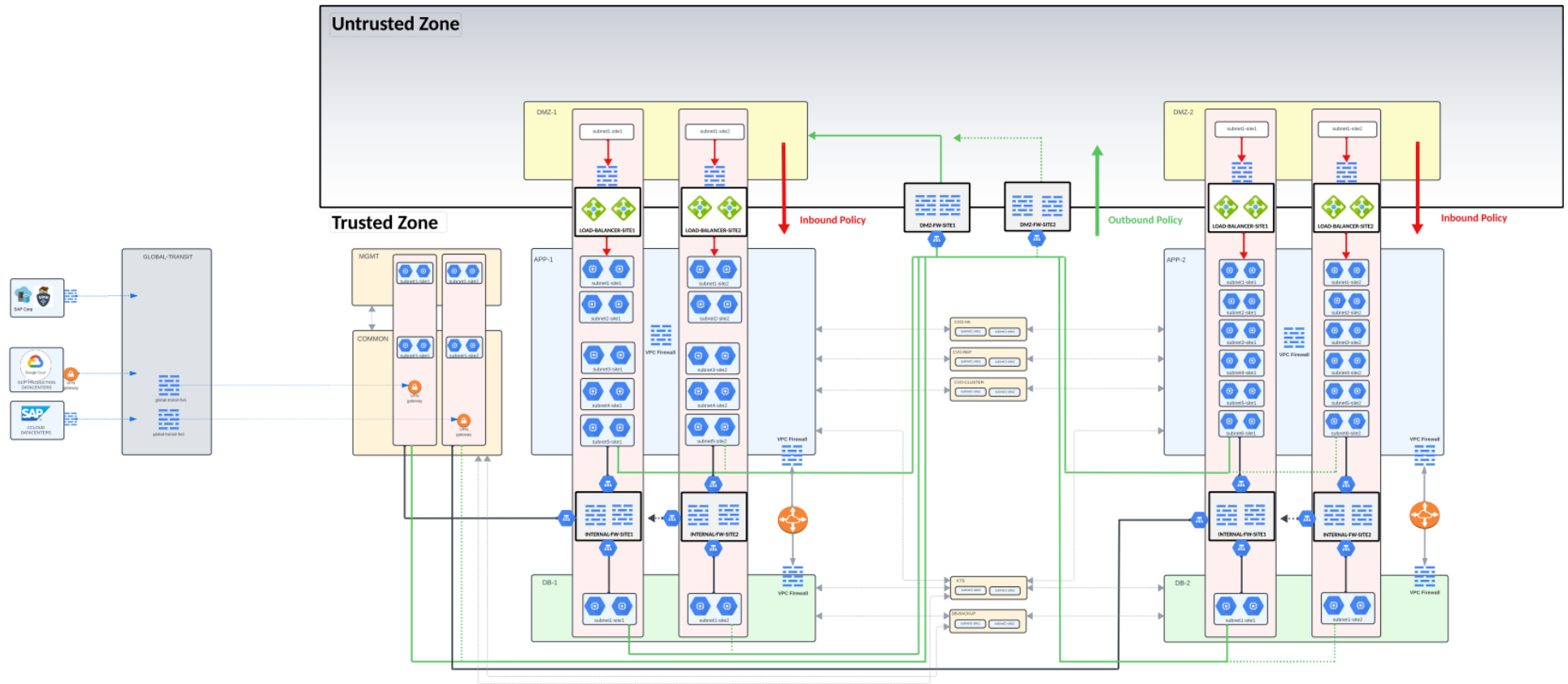
- Web servers
- Application servers
- Database servers
- File servers
- Load balancers
- Firewalls
- Internet connections

The SAP Ariba and SAP Business Network Cloud Solutions environment is designed as a three-tiered model with a web user interface layer, a business application layer, and a database layer. Security zones are established based on this three-tier architecture, along with an internet-facing demilitarized zone (DMZ) and a secured back-office portal used by SAP Ariba and SAP Business Network personnel to maintain the environment and perform problem management as required. The communication protocols used between the systems are Transmission Control Protocol/Internet Protocol based.

Logical Network Diagram



Logical Network Diagram for SAP Ariba and SAP Business Network on Google Cloud Platform and SAP Cloud Infrastructure (SAP Converged Cloud)



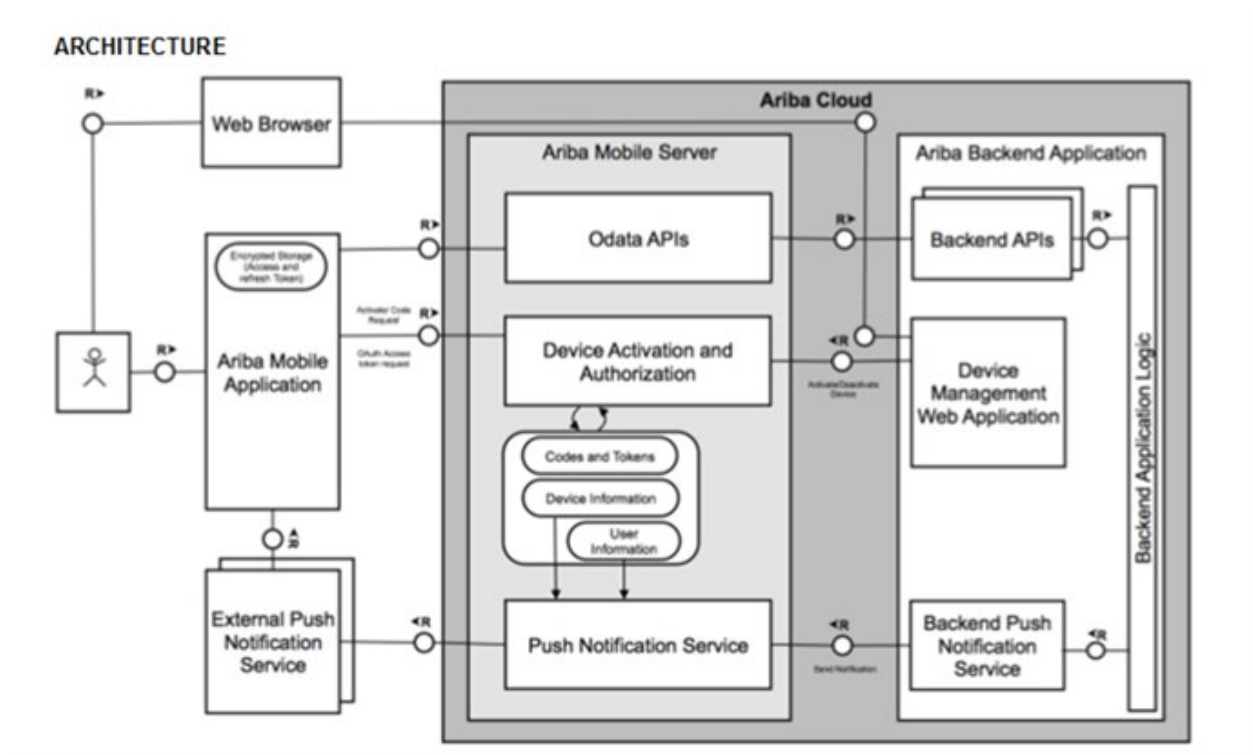
SAP Integration Suite-Managed Gateway

The SAP Integration suite-managed gateway facilitates the integration of buyers' SAP ERP or SAP S/4HANA systems with the SAP Ariba and SAP Business Network.

SAP Ariba and SAP Business Network Mobile Architecture

Security features in the SAP Ariba and SAP Business Network mobile app help protect data and communications between the application and the SAP Ariba and SAP Business Network Cloud. The SAP mobile architecture, as displayed in the figure below, helps ensure that proper security and authentication are in place.

Mobile Architecture



Information Systems Security

This section describes the end-to-end security architecture model for the SAP Ariba and SAP Business Network solutions. SAP Ariba and SAP Business Network operations have standardized operating system installations based on predefined security policies. Servers are configured with just the applications and services required to run the server as designed. Services that are not required are disabled, and binary files that are not required for operations are removed, which reduces the total number of vulnerabilities a system may have.

SAP Ariba and SAP Business Network operations' standardized installation process also helps ensure that servers of the same type are configured in the same manner, utilizing a process that initiates an upgrade to system binaries across all systems. Based on the system type, the configuration will

remain the same. If one server type needs to receive a patch for a vulnerable binary file, that patch is pushed to all systems of that server type. If that binary exists on all systems, it is patched across all systems. Patches are then included in the build process as well so that future systems built will follow security standards. SAP Ariba and SAP Business Network uses this configuration process to harden the operating system prior to implementing additional controls, as detailed below:

- *Web Servers* – Authentication using a unique login/password pair is required when SAP Ariba and SAP Business Network users attempt to access corporate profile information, initiate a transaction, or retrieve information saved from a previous session. HTTPS (HTTP over Transport Layer Security [TLS]) is based on a minimum 128-bit encryption and is used for secure communications between the web browsers and the web servers.
- *Load Balancers* – SAP Ariba and SAP Business Network solutions' load balancers control traffic and guarantee optimal utilization of the web servers. Security is built on top of load balancers to protect the Ariba stack. The load balancers are used as Secure Sockets Layer (SSL)-termination endpoints for TLS 1.2 initiated sessions.
- *Monitoring Servers* – SAP Ariba and SAP Business Network uses a centralized monitoring server for alerting capabilities. It monitors network traffic, processes system messages and alerts, application status, and transaction status.
- *Firewalls* – Firewalls separate the corporate network from SAP Ariba and SAP Business Network infrastructure computers. Therefore, unauthorized SAP Ariba and SAP Business Network employees cannot access SAP Ariba and SAP Business Network data from the corporate network infrastructure. Access is limited to specific roles or functions within SAP Ariba and SAP Business Network Operations. Additionally, access is managed on an exception basis whereby personnel need clearance to be authorized as external connections. Access is time-limited, after which re-authentication is required.
- *Intrusion Detection System* – SAP Ariba and SAP Business Network uses network and host-based intrusion detection. This technology provides logging and alert capabilities to assist in the detection of malicious acts and misuse. Intrusion detection/prevention tools are used to identify, log, and report potential security breaches and other incidents. An automated script generates an intrusion alert, which is reviewed by management.

Separation of Customer Data

In the SAP Ariba and SAP Business Network Cloud Solutions environment, tenants share certain resources; however, their private data is isolated. All tenants share the same version of the application software. This means that only one version of the application is deployed for production use in a data center. Multiple tenants share the same hardware resources, the same applications server instances, and the same storage. Even though resources are shared between tenants, the data of each tenant is always isolated. SAP Ariba and SAP Business Network stores the data of multiple tenants in the same database tables, separated by the tenants' organizational and user IDs.

Scope

This description addresses only SAP's SAP Ariba and SAP Business Network System provided to user entities and excludes other services provided by SAP. The description is intended to provide information for user entities of the System and their independent auditors who audit and report on such user entities' financial statements, to be used in obtaining an understanding of the System and

the controls over that system that are likely to be relevant to user entities' internal control over financial reporting. The description of the System includes certain business process controls and IT general controls that support the delivery of SAP's system. The description does not encompass all aspects of the services provided or procedures followed that are unrelated to internal control over financial reporting activities performed at SAP.

SAP uses subservice organizations to perform certain services. A list of these subservice organizations and the services performed is provided in the following table. The description does not disclose the actual controls at the subservice organizations.

Subservice Organization	Services Performed
SAP Cloud Infrastructure (SCI)	SAP Ariba and SAP Business Network software also runs on SCI. SAP SE accesses data to enable and operate SCI, and to provide support and consulting. It provides a harmonized infrastructure architecture as well as an infrastructure orchestration and automation layer in SAP data centers. It also orchestrates the consumption of hyperscaler services across SAP
Google LLC	SAP Ariba and SAP Business Network software also runs on Google Cloud Platform (GCP). Google LLC accesses data to enable and operate GCP, and to provide support and consulting.
SAP Business Technology Platform (BTP)	SAP Ariba and SAP Business Network software also runs on SAP BTP. SAP SE accesses data to enable and operate BTP, and to provide support and consulting.

Components of the System Used to Provide the Services

Infrastructure

SAP Ariba is deployed in different regions. It is deployed on Google Cloud Platform in North America, Europe, Japan, and Australia. It is deployed on SAP Cloud Infrastructure in China, United Arab Emirates (UAE), and Kingdom of Saudi Arabia. Each regional data center hosts the full SAP Ariba application suite, including all SAP Ariba Procure-to-Pay and Strategic Sourcing applications. The SAP Business Network is considered to be a transit network, like the internet, supporting connectivity between organizations and serving as a central marketplace. This shared resource is housed in North America data centers. Application connectivity between the sites in North America, Europe, China, the United Arab Emirates, the Kingdom of Saudi Arabia, Australis, and Japan is over the public network with secure HTTPs connections.

Within each region, SAP Ariba and SAP Business Network are deployed on two data centers that act as redundant pairs. These data centers are built in a warm stand-by configuration. At any point in time, customers interact with servers in a single data center while data is copied in near real time to the other. For GCP and SAP Cloud Infrastructure, the underlying physical infrastructure is managed by Google and SCI respectively and the software and virtual components are managed by SAP Ariba and SAP Business Network. For the purposes of this report, Google, SCI, and SAP BTP are

subservice organizations. Controls at the respective subservice organizations are not included in the scope of the report.

Primary Data Center ID	Primary Data Center Operated By	Primary Data Center Region Name	Secondary Data Center ID	Secondary Data Center Operated By	Secondary Data Center Region Name
XG1	GCP	USA: Council Bluffs, IA	XG0	GCP	USA: Las Vegas, NV
XGA	GCP	Australia: Sydney	XGA	GCP	Australia: Sydney
XGB	GCP	Germany: Frankfurt	XGH	GCP	Netherlands: Eemshaven
XG9	GCP	Japan: Tokyo	XGJ	GCP	Japan: Osaka
SH3	SCI	China: Shanghai	SH4	SCI	China: Shanghai
RI1	SCI	Saudi Arabia: Riyadh	DM1	SCI	Saudi Arabia: Dammam
DB1	SCI	United Arab Emirates: Dubai	DB2	SCI	United Arab Emirates: Dubai

The infrastructure providers are part of the SAP Supplier Management process and are required to fulfill the security requirements defined in the SAP Cloud Data Center Security Requirements that are part of the supplier contracts.

Software

The following table details the key software components that support the system:

Component	Description
Operating Systems	Linux operating systems
Databases	HANA and Postgres
Monitoring Systems	An in-house tool is used for bandwidth, utilization, uptime, and capacity monitoring and is configured to send real-time email notifications to Cloud Operations personnel when pre-defined thresholds are exceeded on monitored devices.
Active Directory (AD)	AD is used to store the user accounts and group membership to manage access to the production systems. Authorized users are required to have a username and password and have membership on the domain in order to access the production servers.
Lightweight Directory Access Protocol (LDAP)	Open LDAP is a directory service protocol used to authenticate users using AD information.
Safeguard	Safeguard is an IP tables-based firewall system between the SAP corporate network and the Ariba production network that was developed in-house. It applies rules to control authorization and privileges by using Safeguard groups.

Component	Description
Multifactor Authentication	RSA authentication manager is used for two-factor authentications to the production environment.
Virtual private network (VPN)	Big IP F5 is used for VPN connections for remote access.
Anti-Malware	TrendMicro is used as anti-malware on servers.
Vulnerability Management	A web-based third-party service is used for infrastructure vulnerability management, including external network security assessments and penetration testing.
Security information and event management (SIEM)	Splunk is used as SIEM solution and is configured to provide security alerts and act as central log storage tool.
Security Code Review	Source code is maintained in GitHub. GHAS and Checkmarx are used for static security scans, DASTer for dynamic security scans, and Mend and Black Duck for open-source vulnerability scans.
Intrusion Detection System (IDS)	Palo Alto Next Gen firewalls are installed as an IDS solution.
GCP Project Provisioning	Terraform is used to provision projects on hyperscalers
Configuration Management	Linux, along with Salt and CFEngine, is used to push changes to the production environment and manage cron jobs. Ansible is used for configuration hardening of images
Network Management	Palo Alto Next Gen firewalls are deployed.

People

The following table details the key teams that support the system:

Team	Responsibilities
Cloud Operations	- Monitoring the system landscape for availability and performance. - Provisioning tenants (access to application for customers). - Infrastructure capacity management. - Continuous improvement – availability, system configuration, capacity, and compliance.
Executive Management	- Establishment of product vision, including end-to-end cloud service to the customer, which includes infrastructure, hardware, cloud solution of choice, operations, maintenance, and customer service. - Overseeing of company-wide activities. - Attainment of business objectives. - Commitment and assignment of leadership responsibilities for information security and data privacy.

Team	Responsibilities
Product Management	- Working closely with Engineering teams to help ensure product improvements are tracked, implemented, and released in a timely manner. - Working closely with customers to get feedback and gather requirements for product improvements. - Developing, testing, and deploying changes and improvements to the application.
Sales Operations	Client implementation, renewal, and account management.
Customer Support	- Single point of contact for customer issues. - Day-to-day customer support. - Provisioning tenants (access to application for customers).
Information Security and Compliance	- Security program ownership, assignment of security responsibilities, and policy management - Security monitoring and compliance. - Vulnerability management and penetration testing. - Vendor management and compliance. - Organizational security awareness.

Data

The following describes the different types of data used by SAP Ariba and SAP Business Network cloud solutions:

- **Master Data** – Master data are data that are relatively static and represent a common point of reference. Examples of master data in an SAP Ariba and SAP Business Network cloud solution are:
 - Employee (user) data
 - Organizational hierarchy and accounting data
 - Product information, including pricing
 - Payment terms
 - Supplier company name, address, and other identification information
 - Customer identification information
 - Currency information
 - Unit of measure information

The specific master data supported and required depends on the customer's SAP Ariba and SAP Business Network cloud solution and business process requirement. For a full list of available master

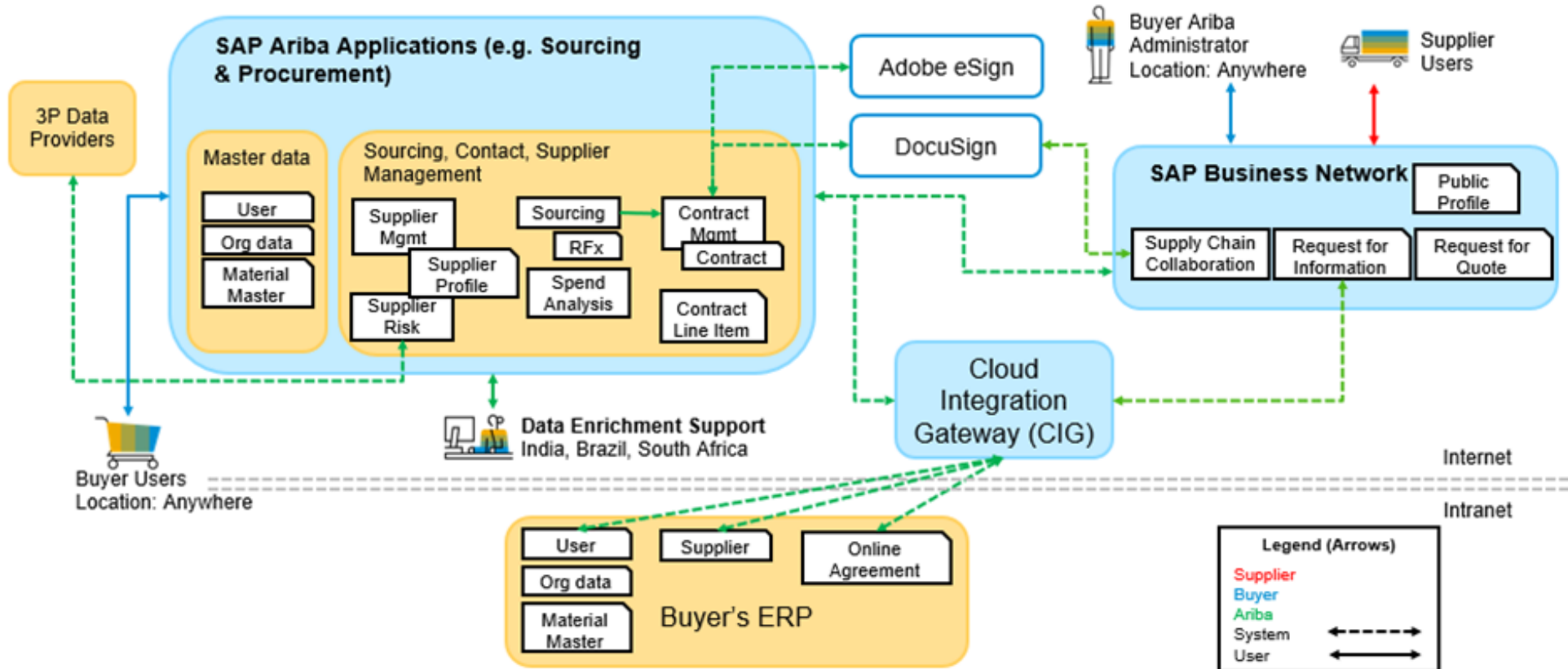
data, see the product documentation of the respective customer solution. Most master data can be imported and synced with the customer's back-end system.

- *Transaction Data* – Typical transactions in SAP Ariba and SAP Business Network cloud solutions include purchase orders, order confirmations, invoices, service sheets, and payment advice documents. A transaction describes a specific event, such as sending a purchase order to a supplier or alerting a supplier that payment of an invoice has been approved.
- *Project Data* – Project data is a type of transaction data for SAP Ariba Strategic Sourcing solutions. Project data includes sourcing events such as requests for information requests for proposal, or auction events or contract data consisting of contract workspaces, documents, clauses, and tasks.

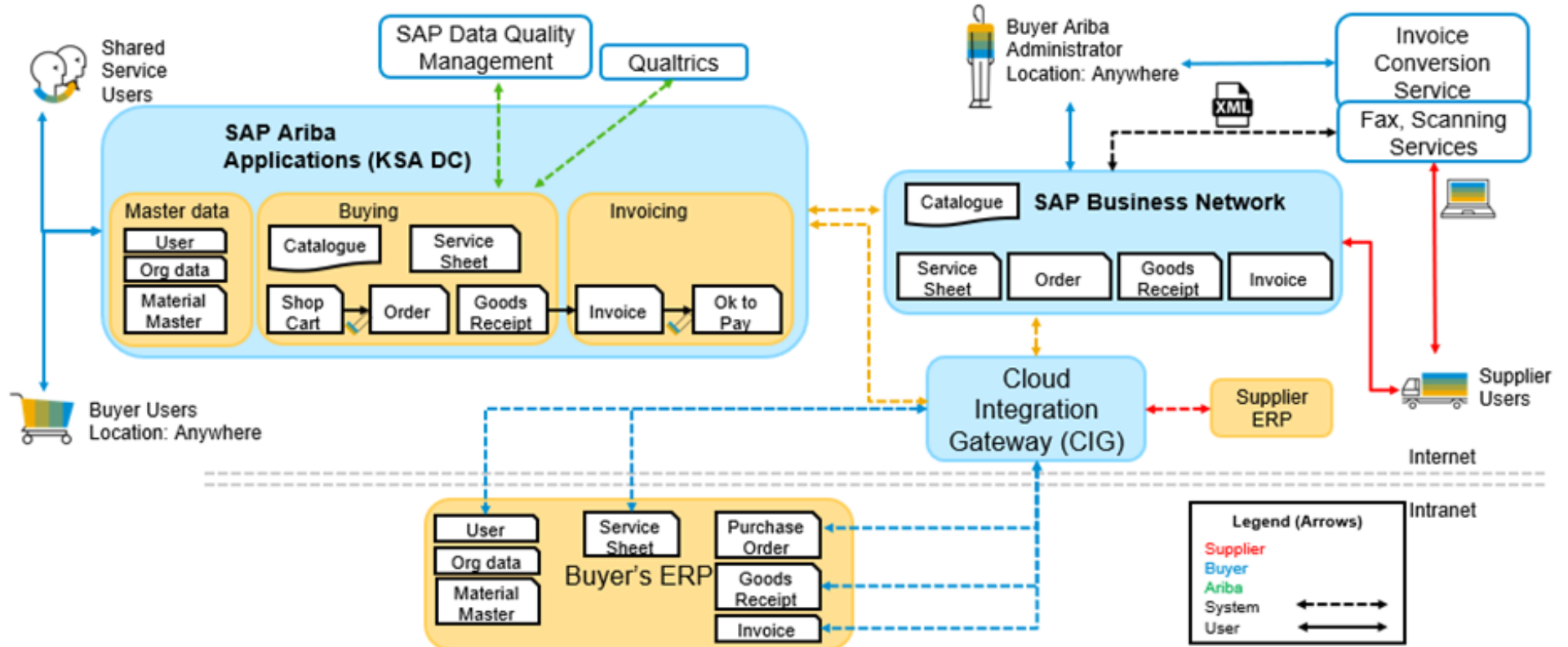
The data flows for the main SAP Ariba and SAP Business Network applications are depicted in the following figures.

The remainder of this page intentionally left blank.

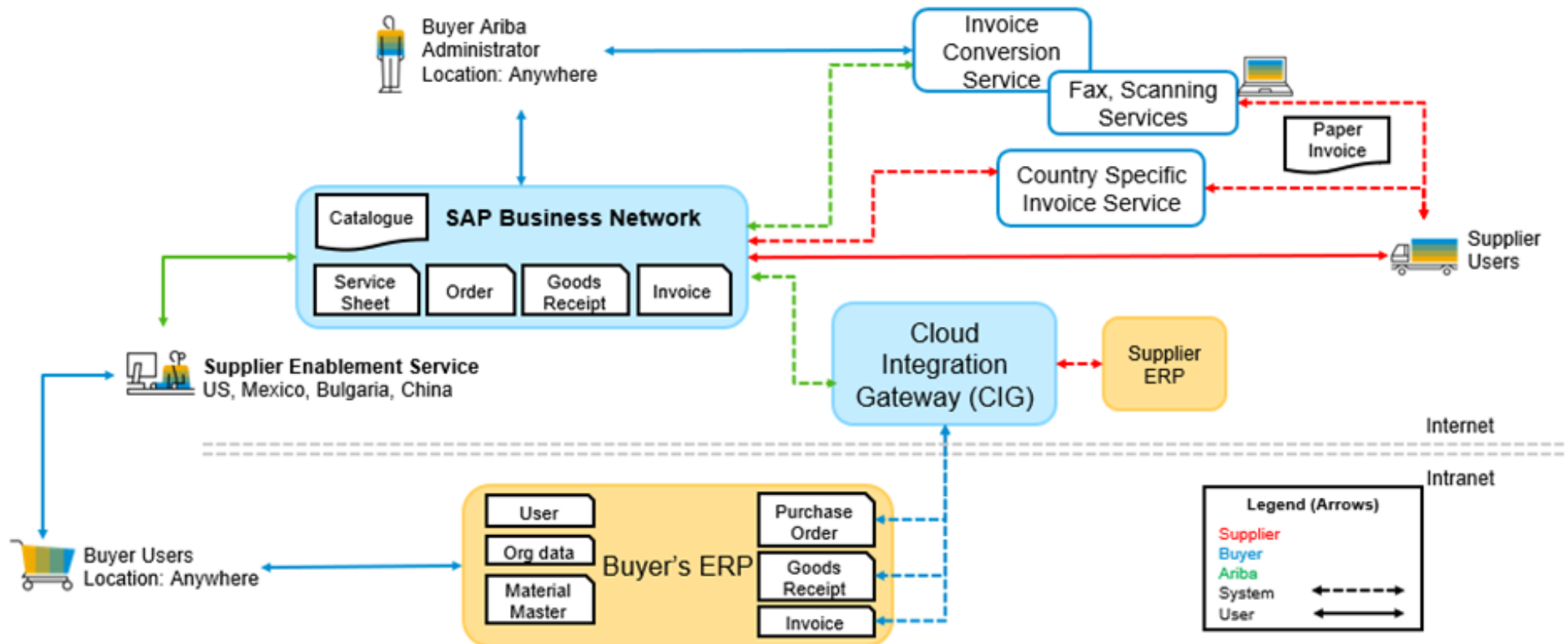
SAP Ariba Sourcing Data Flow



SAP Ariba Procurement Data Flow



SAP Business Network Data Flow



Internal Control Framework

This section provides information about the five interrelated components of internal control at SAP: control environment, risk assessment process, monitoring activities, information and communications, and control activities.

SAP's internal control components include controls that may have a pervasive effect on the organization, specific processes, account balances, disclosures, classes of transactions, or applications. Some of the components of internal control have more of an effect at the entity level, while other components are primarily related to specific processes or applications.

Control Environment

The control environment sets the tone of an organization, influencing the control awareness of the organization. The control environment is embodied by the organization's awareness of the need for controls and the emphasis given to the appropriate controls through management's actions supported by its policies, procedures, controls, and organizational structure.

Commitment to Integrity and Ethical Values

SAP Code of Business Conduct

SAP defines standards for conduct in business, legal, and ethical matters carried out on a daily business. The Code of Business Conduct is reviewed and acknowledged by each employee as part of the new hire onboarding and annually thereafter. Employees are notified of amendments to the Code of Business Conduct via the corporate portal and email.

Oversight Responsibilities of the Supervisory Board

Corporate Governance

The SAP SE Supervisory Board (Supervisory Board) is an independent governing and supervising body that provides oversight and strategic direction for the organization. The size and the composition of the Supervisory Board are determined by the Articles of Incorporation and the Agreement of the Involvement of the European Employees in SAP SE. SAP's Supervisory Board is comprised of members elected by the shareholders at their General Meeting and members representing the European employees of the SAP Group.

The Supervisory Board has defined a catalog of skills and expertise collectively required of its members so that it possesses the knowledge, ability, and professional experience required to properly perform its function.

The Supervisory Board has appointed committees to prepare its deliberations and implement resolutions. Information about each Supervisory Board member, and the committees and their composition, is available on the company website.

On an annual basis, the status of internal controls is formally reported to management and the Supervisory Board. The report details assessment results, as well as related follow-up activities.

In addition, SAP has an independent Internal Audit function reporting to the Chief Financial Officer, the Chief Executive Officer of SAP and the Supervisory Board's Audit and Compliance Committee. SAP's audit charter defines Internal Audit's purpose, authority, responsibility, and position. Internal Audit reports on the audit planning and the audit results to the Supervisory Board on at least an annual basis. The audit program is developed following a risk-based approach and includes, among other areas, IT Security related topics.

Assignment of Authority and Responsibility

Formal organizational charts and detailed reporting structures for each functional group within SAP are defined, maintained on a regular basis, and can be accessed by all employees via the SAP Employee Network section in the SAP Portal.

SAP Global Security and Cloud Compliance (SGSC) has developed the SAP Security Policy Framework, which comprises the security-relevant requirements and implementation guidelines for business units and subsidiaries of the Company. The framework is built on the following structure:

- *Security Policy* – A high-level document that defines management strategy, expectations, and direction. It establishes the strategic goals and objectives that the organization strives to achieve in order to maintain the highest level of security.
- *Security Standards* – A document that defines the minimum requirements for adherence to a policy. These requirements can be met by executing the corresponding procedure(s).
- *Security Procedures* – A series of sequential tasks that are performed to achieve an outcome. Procedures can be the step-by-step instructions to implement a standard when appropriate.
- *Security Good Practices* – A checklist for employees to simplify the policy implementation process.

Commitment to Competence

The objective of the Human Resources (HR) Security process is to evaluate and manage personnel in accordance with SAP policies. The SAP hiring procedures include a screening of the candidates/employees for key positions/highly secured access areas and consideration of whether the verified credentials are commensurate with the proposed position/highly secured access areas required. These procedures do not cover SAP internal changes to positions or new employees added due to mergers and acquisitions, except if highly secured access is needed. New personnel are selected according to the criteria specified in dedicated job descriptions and are offered employment contingent on the background check and assessment of their prior roles. These checks validate (where legally permissible based on the new employee's country of residence/country hired into) employment details such as job history and roles, education, criminal record, politically exposed person checks, and proof of identity. SAP performs the background check using a global external vendor. For countries where employment and education checks are not permitted, HR reviews additional information submitted by the employee during the application process. In accordance with local laws and regulations, background checks are limited to standard HR checks at the time of hiring: academic credentials and professional career (including verification of letters of reference, where appropriate), as well as identity validation for security purposes. These tasks are performed by HR and Security, respectively, and are not outsourced to a third party.

In case of any findings during the background check, an adjudication process is defined in accordance with the criticality of the finding.

The following mandatory documents must be acknowledged and/or signed by the selected candidates before they receive access to customer systems:

- *Code of Business Conduct* – Explains SAP’s policies.
- *Non-Disclosure Agreement (NDA)* – Prohibits any disclosure of information that is classified as internal, confidential, or strictly confidential. Access to SAP systems, protected areas, etc., is not granted unless the NDA has been signed by the employee.
- *External Worker Statement (EWS) and other contractual confidentiality provisions* – SAP vendors and third-party service providers with access to confidential information are subject to the EWS and other contractual confidentiality provisions. As with the NDAs, the EWS must be signed before access is granted to SAP systems, protected areas, etc.

Notice of an instance of non-compliance with the Global Security Policy is issued to the employee by an employee’s manager (or member of the management team) with an HR representative present. Depending on the sensitivity of the issue, an investigation is initiated, and disciplinary sanctions are agreed upon (e.g., verbal warning, written warning, suspension, termination).

Allegations of non-compliance with the SAP Global Code of Ethics and Business Conduct are assessed by designated investigation teams; depending on the legal nature of the allegation, subsequent investigations are performed. The mandate of the Office of Ethics and Compliance addresses compliance areas of corruption, bribery, and substantial fraud. If the allegation in these compliance areas is substantiated, the relevant consequence management process is initiated by the Office of Ethics and Compliance and executed by the direct management of the employee involved and HR to impose disciplinary sanctions.

For sensitive and confidential matters and issues, the SAP Speak Out Tool provides employees a channel to anonymously report any concerns or complaints, including questionable accounting or auditing matters. The corporate whistleblower channel is established and communicated to the organization on a global level. This is monitored by the Office of Ethics and Compliance. Other matters submitted via this tool are forwarded to the appropriate department for further follow-up.

SAP centrally offers to all of its employees opportunities to continuously develop themselves for their current roles and future ones via a learning platform where mandatory as well as optional training courses are offered. SAP has a continuous goal-setting process based on a corporate-wide standard and system-based workflow that is aligned with employees’ job responsibilities. The goals are set by the employees together with their managers and are captured in the goal-planning tool. Dialogues between the employees and managers are performed and feedback or changes, if required, are recorded in the tool on a continuous basis. A semiannual report on the rate of compliance is generated by the central talent team and action is taken, if necessary. SAP also has a performance-oriented compensation approach, which is intended to reward performance.

HR is notified of the end of an employee’s contract via the HR system workflow triggered by the employee or the manager. Once the workflow has approved the termination, information is updated in the HR system. Subsequently, the departing employee and, if applicable, the respective manager are notified of offboarding activities, including the requirement to return IT assets to SAP. SAP IT

Client Services manages the returned IT assets and performs the necessary security measures on the returned IT assets. If the IT assets are not returned, follow-up actions will be performed.

Accountability

Security Governance

The SGSC organization is co-led by SAP's Chief Security Officer and Chief Security Compliance & Risk Officer, who report directly to the Chief Technology Officer. SGSC is responsible for protecting the brand, people, assets, intellectual property, customer data, and information technology of SAP from misuse or compromise.

SGSC supports cross-functional end-to-end security processes by:

- Providing a clearly defined Security Governance Model. The model builds on the SAP Global Security Governance Framework as well as the Operating Model for Security at SAP. It streamlines the interaction within SGSC and the alignments between SGSC and key stakeholders. It comprises the management of day-to-day activities, the execution of key security projects, as well as the interaction with critical stakeholders, on an execution, steering, executive, and Board level.
- Defining an Operating Model for Security at SAP with clear roles and responsibilities. The Operating Model defines how the security functions are delivered through the central security departments. It defines actions, sets priorities, and assigns clear roles and responsibilities. SGSC performs periodic reviews that identify areas for improvements within SGSC, Intelligent Enterprise Solutions (IES), Global Cloud Infrastructure & Delivery (GCID), Product Engineering (PE), Technology and Innovation (T&I), and other areas.
- Supporting process implementation and adoption.
- Harmonizing security tools in use.

The SAP Security Policy Framework consists of several levels of security documents that support the requirements set forth in the SAP Global Security Policy. LoBs may also have supporting policies, standards, procedures, and good practices. SGSC maintains the Global Security Policy, Standards, Procedures, and Good Practices to effectively provide global security governance. The Policy is a living document subjected to modification as needed to protect SAP as new threats and vulnerabilities are identified or the risk profile of the organization changes. The Policy must be reviewed annually or sooner if significant changes occur. Formatting, editorial, clarification, and minor content revisions are approved by the SAP Chief Security Officer.

SGSC partners with the Business Information Security Officers and other security representatives from all LoBs, GCID, IES, and central development teams from several board areas, such as PE and T&I, to provide centralized and federated coverage through various functional areas that include but are not limited to Security Operations, Security Training, Communications, Cyber Intelligence, Vulnerability Management, Security Architecture, Product Security, Governance, Risk, and Compliance (GRC), Sales & Enablement, and SecDevOps Guilds.

SGSC pursues the following key objectives:

- For both Cyber and Physical Security, enact a multi-dimensional security and compliance approach for development units and security stakeholders to address legal requirements.

- Safeguard SAP's customers, employees, data, and assets.
- Meet market security requirements: Support LoBs, Customer Success, and centralized stakeholders (IES, GCID, Secrecy, Data Protection and Privacy, etc.) by securing products, development lifecycle, and sales.
- Detect, monitor, and mitigate security risks and prepare SAP to meet security compliance requirements.
- Train SAP employees in security basics and train experts to proactively reduce security risks. SAP internal and external employees are informed about the SAP Global Security Policy and the SAP Global Information Classification & Handling Standard.
- Mitigate the damage/impact of possible forces of nature.
- Make security training mandatory for existing personnel, newly hired employees, and external staff members. The manager of each employee/staff member is informed regarding the completion of, or failure to complete, the mandatory training.

Risk Assessment Process

The objective of the Risk Management process is to properly identify, assess, prioritize, and manage (i.e., minimize, monitor, and control the probability and/or impact of events with negative impact) risks (e.g., regulatory, financial, operational, and fraud risks) to the Company. The SAP Global Risk Management Policy communicates the SAP Executive Board's expectations on how risks are to be managed within SAP. It sets out company-wide standards for managing risk across the LoBs and establishes the key risk management responsibilities within SAP.

The Global Risk Management Policy defines risk management methodologies, activities, and organizational requirements for achieving the policy objectives. SAP's risk management model comprises of five process steps:

- Risk planning
- Risk identification
- Risk analysis
- Risk response
- Risk monitoring

SAP performs risk assessments to identify, quantify, and prioritize risks against criteria published in the SAP Global Risk Management Policy. Each LoB performs risk assessments in alignment with the Global Risk Management Policy and guidelines. Risks that exceed a certain level of risk exposure are documented in the Central Risk Repository (GRC Software Solution). Each risk is then mitigated to an acceptable level or accepted in accordance with the Global Risk Management Policy. For example, risks may be accepted if the cost of implementing the mitigation exceeds the risk exposure or business impact.

Monitoring Activities

SAP has developed and implemented an integrated framework based on information security management, quality management, and business continuity principles. The framework brings the

SAP Global Security Policy with SAP's Security Standards, the SAP Quality Policy, and Standards on Business and Service Continuity together.

SAP maintains and updates its management system by establishing policies, procedures, and processes to achieve its control objectives. Management review meetings occur at least annually, where management reviews SAP's management system to help ensure its continuing suitability, adequacy, and effectiveness. The management review includes, at a minimum, the status of action items from previous management reviews, helps identify and implement required changes to the management system, encompasses feedback from audit results, including the results of examinations performed over the carved-out subservice organizations, identifies and assesses requirements of relevant internal and external stakeholder, legal, and regulatory requirements, and the results from a regular risk assessment. Lastly, the management review addresses the fulfillment of management objectives and opportunities for continual improvement and tracks necessary corrective actions.

Monitoring of Subservice Organizations

Supplier Management

The objective of the Supplier Management process is to provide assurance that critical suppliers adhere to the agreed level of security and service delivery.

The compliance of subservice organizations with SAP's security requirements is periodically reviewed and verified by SAP audit procedures. Certain control objectives can be met only if the subservice organization's controls, assumed in the design of SAP's controls, are suitably designed, and operate effectively along with related controls at SAP.

Information and Communications

Internal Communication on Security, Availability, and Confidentiality Topics

SAP has implemented various methods of communication at a global level to help ensure employees understand their roles and responsibilities and to communicate significant events in a timely manner. These methods include orientation and specific training programs that relate to security, availability, and confidentiality for newly hired employees, regular management meetings for updates on business performance and other matters, mandatory security awareness and secure communication training, the use of email messages for time-sensitive information, and articles on the SAP intranet. Any changes to the security policies and standards are communicated via email campaigns and articles on the SAP intranet.

Procedures for Exchanging Information

SAP IT systems are configured to protect transmitted information in accordance with requirements. Suitable measures for securing the exchange of information are in place, including:

- Utilization of email encryption.
- Provisioning of secure network protocols and interfaces.
- Encrypted communication lines.
- Application of the Information Classification Security Standard.

Communication of the Cloud Contract Information

Contracts for cloud services from SAP consist of three components:

- *Cloud Service Description* – This includes the term of the specific cloud service, the support schedule, and the operational availability of the cloud service.
- *Data Processing Agreement* – Based on the instruction from the data processor who handles the personal data uploaded to the cloud service, SAP implements and maintains technical and organizational measures to adequately protect personal data.
- *General Terms and Conditions (GTC)* – The GTC document describes the essential legal terms that apply to the specific cloud service, including the related usage rights, customer data, warranties, confidentiality, and the limitations of liability provisions.

SAP Trust Center

SAP has implemented and maintains a review and audit program to comply with the requirements of specific compliance and security standards. The list of applicable attestations and certifications is available online in the Compliance section of the SAP Trust Center.

The SAP Trust Center is a self-service center where customers can initiate requests and collect information related to security and compliance for cloud services and on-premises software. The SAP Cloud contract information is also available for customers in the SAP Trust Center.

In the other subsections of the SAP Trust Center, customers can confirm data center locations and view cloud-based status information such as availability, downtime, and maintenance window. SAP has established dedicated notification processes, in accordance with contractual requirements, in case the Company fails to achieve one or more of its commitments or control objectives. Confidential information, such as mentioned above, is only disclosed via these dedicated channels.

Control Objectives and Related Control Activities

The service organization has developed a variety of policies and procedures, including related control activities, to help ensure that the service organization's objectives are carried out and that risks are mitigated. These control activities help ensure that services are administered in accordance with the service organization's policies and procedures.

Control activities are performed at multiple levels throughout the organization and at various stages during the relevant business process. Controls may be preventive or detective in nature and may encompass a range of manual and automated controls, including authorizations, reconciliation, and IT controls. Duties and responsibilities are allocated among personnel to ensure that a proper segregation of duties (SoD) is maintained.

SAP has specified the control objectives and identified the controls that are designed to achieve the related control objectives below.

Control Objective 1 – Backup and Restore

Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up regularly and procedures are employed to maintain the integrity of the data backup.

The objective of the Backup and Restore process is to back up (copy) and store data in remote locations where it is protected until needed, such as when a loss of data has occurred, and the data must be restored. The Backup and Restore process is supported by Backup and Restore services, which help ensure the integrity of customers' data by restoring corrupted data when necessary.

The Backup and Restore services are operated to mitigate the risk of data loss that may threaten customers' operational activities or reputation. The following description outlines how backups are taken, how the data is protected, and how backups are restored for SAP's cloud services.

The Backup and Restore process is based on the SAP Security Policy Framework, which follows SAP's Cloud Infrastructure Security Procedure and Key Management Security Procedure.

There are two processes for protecting data: Backup Management (Perform Backup) and Restore Management (Perform Restore).

Backup Management (Perform Backup)

Backup agents are installed and backup jobs are scheduled on the corresponding database server. An initial full database backup is performed. After the successful initial backup, the new system is integrated into the landscape and the backup status is monitored via the respective monitoring tool.

Backups are performed on a regular basis for in-scope production systems. Relevant backup database systems are monitored on a daily basis. If backups are not running or encounter errors, backup error alerts are generated. The alerts are addressed within predefined time frames, and corrective actions are initiated and documented. Errors are either resolved by the Backup team or forwarded to the appropriate support group if needed.

Backup data is stored on two different backup devices physically located in different regions. This is achieved via replication. Backup data is encrypted according to SAP policies and standards in accordance with the requirements related to the data being backed up.

Encryption keys may be stored at the hyperscalers, which owns, accesses, and manages them. SAP does not have access to the encryption key material. However, SAP authorized personnel are able to manage the keys by performing limited actions, such as schedule creation, schedule deletion, and tenant assignment.

Restore Management (Perform Restore)

Validation of the reliability of the backup media and restore process, data restoration functionality testing is performed at least annually. The testing procedures and results are documented.

Further, customers or customer representatives from cloud services (restore requestor) can request restores by submitting a Service Request (SR) in the respective ticketing system. The restore requestor must use the corresponding template and provide the necessary information.

The Restore Processor receives and validates the restore requirements, validates that the restore requestor is authorized to request the restore, and documents the results in the ticket. If the validation fails, the SR is rejected, and the Restore Processor provides the reasons for the rejection. If the validation is successful, the Restore Processor proceeds with the restore. The Restore Processor checks that the backup data and backup media are available as required to perform the restore.

The Restore Processor documents the successful completion of the restore procedure in the ticket. The Restore Requestor can manually confirm the restore success.

Control Objective 2 – Change Management

Controls provide reasonable assurance that changes to the production environment relevant to user entities' internal control over financial reporting are authorized, tested, documented, approved, and implemented.

The objective of the Change Management process is to provide reasonable assurance that changes to the production environment are authorized, tested, approved, and implemented in a controlled manner.

Overview

SAP Ariba and SAP Business Network follows a Product Lifecycle Methodology (PLM) for product development. The methodologies vary slightly depending on product maturity and the type of development (e.g., new applications versus incremental features). In all cases, the methodologies define:

- Specific phases, activities, and deliverables.
- Entry and exit criteria, including reviewing feature completeness, quality trends, test case execution, and test case automation, as well as security reviews.
- Formal exit reviews, with final approval by SAP Ariba Products Development leadership or their delegates.

SAP Ariba and SAP Business Network's development process is based on the Agile development methodology, with cross-functional teams called "feature teams" or "scrum teams." Since requirements are difficult to capture in documents, Agile concentrates on having constantly running software in development that can be iterated quickly. Feature teams are responsible for planning and delivering sets of related features. Those teams typically include members from Development, Quality Assurance, Product Management, User Assistance, Globalization, and Readiness. In some cases, the team may also include members from the Production Operations and the User Experience teams.

Changes are developed and delivered via one of the following approaches:

- *Feature-Based Development* – New features and enhancements are developed independently utilizing Agile with Scrum for execution.
- *Sustaining* – Production defects are reviewed and resolved under a controlled change management process. Critical defects are fixed via hot fixes (HFs) or data fixes. Other important fixes are addressed via regularly scheduled service packs.

SAP Ariba and SAP Business Network releases software updates on a frequent basis to customers. Each release contains:

- Feature-based development features
- Incubation features
- Defect fixes

SAP Ariba typically deploys one consolidated customer-facing release per month containing:

- *SAP Ariba Applications* – A release that delivers updates to SAP Ariba Sourcing and Procurement solutions
- *SAP Business Network* – A release that delivers updates to the Ariba Network

To help ensure customers know what each release contains, a release information is published to customers that includes a bill of materials that highlights the content contained in the release.

In addition, SAP Ariba and SAP Business Network may deploy additional releases of underlying infrastructure applications that are not directly exposed to the customer. These releases support the Sourcing, Procurement, and Network solutions.

Feature-Based Development Model

A key aspect of feature-based development is that features are developed and deployed independently. Once a feature has met the exit criteria and has been approved, it is considered ready for production. Teams will frequently work on multiple features concurrently. In some cases, a collection of features may have cross-dependencies, as in the case when a new internal service is being delivered for the first time.

Planning

In feature-based development, features are reviewed, prioritized, and slotted for future sprints on a regular basis. This may be quarterly for some teams and as often as weekly for more dynamic teams.

Development

The Development phase is defined by a set of development sprints. A sprint is a fixed unit of time, where new units of functionality (use cases) are added to SAP Ariba and SAP Business Network applications. Sprints are generally two to four weeks long. The result of each sprint is workable, demonstrable code that can be shown to customers for feedback. Features will be developed in one or more sprints.

For a selected innovation, SAP Ariba and SAP Business Network development may work with customers. During development, features may be reviewed with select design partners after every sprint, and requirements are adjusted based on this feedback loop.

New feature code is protected by a toggle that disables the code until the feature is enabled once it has met standard release requirements. Customers may enable the feature in their test sites to prepare for the adoption of changes.

The Development phase for a feature ends once all exit criteria are met and approved. Exit criteria include security reviews, testing, documentation, and other requirements. Once the feature has been approved, it is considered ready for production pending further readiness activities.

Sustaining

SAP Ariba and SAP Business Network formally tracks production system changes in Jira for full change management.

Changes to production follow a defined review and approval process:

- Changes are deployed in the monthly or weekly release.
- Urgent issues that cannot wait for the next release are deployed through HFs. HFs undergo review, build qualification, testing, and approval.
- Releases undergo a full qualification cycle with automated and manual testing and must meet specified exit criteria.
- Change requests (features, enhancements, and defect fixes) are tracked in Jira, and all code changes are managed in a version control system (e.g. GitHub).

Quality Assurance

SAP Ariba and SAP Business Network uses the following quality control processes and tools:

- Technical Reviews (during design and implementation)
- Automated Testing and Manual Testing (including ad hoc testing)
- Performance and Stress Testing, as needed

Technical Reviews

Prior to implementation, design reviews by either a principal Engineer or Architect are required. During implementation, a code review, performed by two reviewers, is required. Code cannot be checked in until both reviewers approve the code (system-enforced). Application changes are managed in GitHub.

Testing

SAP Ariba and SAP Business Network leverages an automation test suite (both unit and UI-level). Automation also allows SAP Ariba and SAP Business Network to manage and maintain the release quality throughout the development lifecycle. The automation suite is run for every build during the full development lifecycle.

In addition to the automation suite, SAP Ariba and SAP Business Network executes a test suite of manual test cases. Each week, feature teams perform regular ad hoc “group” testing on new functionality.

Code is scanned using dynamic and static code scanning tools to identify potential security and code flaws.

SAP Ariba and SAP Business Network management reviews the pass rate for all releases for both automation and manual testing prior to approving a release.

Performance/Stress Testing

Performance testing, validation, and monitoring are integral parts of the SAP Ariba and SAP Business Network development and production operational models for larger changes.

During feature development, the design of every feature is reviewed for performance impacts. Where applicable, automated unit tests are written to help ensure critical performance measures are met as part of the feature development exit review.

SAP Ariba and SAP Business Network executes performance testing in a lab environment to simulate the production environment. Two different types of testing are performed in this environment:

- Stress testing is a test suite designed to simulate production-like transactions under load (thousands of users over multiple realms/communities with 30 million catalog items).
- Stability testing (or longevity testing) is a long-running test suite used to help ensure that there are no issues due to extended usage of the system.

After product release, SAP Ariba and SAP Business Network has metrics that are constantly monitored to help ensure the performance of the production system from system level (memory, disk I/O, database connections, etc.) to the application level (page response times, business transitions, etc.). The SAP Ariba and SAP Business Network teams work with customers to understand their usage requirements to help ensure their needs are accounted for during production capacity planning and that production system performance standards are maintained during peak periods. Trend-based monitoring is used to track production system metrics and help ensure that there is sufficient capacity for ongoing growth.

SAP Ariba PLM Adherence

Regardless of the methodology followed, change control releases are documented within source code control systems such as Git or other document management systems such as the Confluence Wiki. This includes requirements, design, and test approach documents for all features. All test cases and results are documented and tracked.

All exit criteria, including release approval documents, are tracked in a document management system. All source code and important project documentation is kept in a version control system.

Features undergo a security impact analysis before implementation.

Prior to production implementation, all changes to applications, including emergency changes, require complete documentation based on established procedures and checklists with sign-off approval from Engineering Development management before the Production Operations team will apply the changes.

Asset Management

Asset Management includes a range of activities that allows SAP to manage the inventory and monitor assets related to the system during their lifecycle. Core Asset Management activities rely

on the integration of asset data across several Asset Management tools. Key attribute data for physical and virtual assets is recorded. Production assets are identified in an asset inventory.

Hyperscaler and SAP Converged Cloud Account Management

Hyperscaler accounts within SAP are tracked and managed against each organization unit. A central catalog of hyperscaler accounts utilized within SAP is maintained, providing information about key data elements. The tracking of this information allows for proper governance and security.

Control Objective 3 – Network and Communication Management

Controls provide reasonable assurance that network infrastructure relevant to user entities' internal control over financial reporting is configured to result in valid, complete, and accurate processing and reporting and to protect data from unauthorized changes.

The objective of the Network Communication and Security Architecture process is to provide security measures that prevent unauthorized logical access on the SAP Cloud Network levels where the customer systems are managed and run. The SAP Cloud Network is separated from the SAP Corporate Network via a firewall.

Firewalls and Network Architecture

Firewalls are implemented at the network level to help ensure that unauthorized network traffic is filtered and security at the network level is provided. Changes to the filter set are approved, logged, and traceable to the user who performed the change. Firewall configurations are reviewed at least every quarter.

Network architecture diagrams for the production environment include the design of security zones for network segmentation. These diagrams are documented and reviewed at least annually.

Encryption in Transit

SAP Ariba and SAP Business Network uses, at a minimum, 128-bit TLS encryption for the transmission of private or confidential information over public networks.

Intrusion Detection

SAP Ariba and SAP Business Network deploys network intrusion detection/prevention appliances. The intrusion detection/prevention solution provides logging and alert capabilities to assist in the detection of potentially malicious acts or misuse. Logs are sent to the central SIEM for triaging and tracking. The SAP Ariba and SAP Business Network Central Security team reviews logs generated by the intrusion detection/prevention sensors, and potential incidents are subsequently addressed, resolved, and reviewed by management. Palo Alto intrusion detection and prevention systems provide additional vulnerability protection, network anti-malware, and anti-spyware into one service that scans all traffic for threats – all ports, protocols, and encrypted traffic. This provides for scanning for threats at all points within the cyber-attack lifecycle, not just when it first enters the network – providing a layered defense, zero trust model with prevention at all points.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

The objective of the User and Access Management process is to help ensure that logical access to the solutions' production systems and supporting tools is reasonable and restricted to properly SAP-authorized individuals.

SAP has established and documented identity management, access control, and password policies. These policies define password requirements and access controls to help maintain authorized user access and to prevent unauthorized access to information systems. The allocation and use of privileges are restricted and controlled. Appropriate authentication methods are used to control access by remote users.

Identity Management and Authentication

All users, SAP employees, and external workers, have a unique identifier (user ID), and a suitable authentication technique is used to substantiate the user's claimed identity. These unique user identifiers are used whenever an employee or an external worker accesses production systems.

Session management mechanisms are in place to manage the lifecycle of user sessions.

Employee Central (EC) serves as the HR system for SAP employees, while Fieldglass (FG) functions as the HR system for external workers. SAP utilizes the SAP IT Identity Management System (IDM) to synchronize SAP Global AD daily, which is then used to access Safeguard for authenticating to production with role-based privileged credentials.

Individual accounts for Secure Shell Protocol (SSH) access are managed by Lightweight Directory Access Protocol (LDAP).

Request Access Rights

Access rights for support and maintenance reasons can only be requested by internal SAP employees or contractors. The process for requesting access rights is initiated by the requestor, who submits an access request in an Access Management Tool, including a reason why the access rights are needed.

Approve Request

The approver receives, evaluates, and approves or rejects the access request. Depending on the Access Management tool, the approver can restrict the validity period of the requested access rights up to pre-defined maximum.

Policies governing logical access to the SAP Ariba and SAP Business Network, including SoD, have been documented and communicated to System Administrators. User additions and modifications must be authorized by SAP Ariba and SAP Business Network Operations management, and user revocation must happen in a timely manner after employees are terminated.

Further, system administration-level access to the production servers is restricted to authorized personnel and subject to two-factor authentication. SAP Ariba's password settings are configured in accordance with the SAP Global Security Standard.

A production access request workflow has been created to grant access to the production environment. Each production access request is required to be approved by the requestor's manager, the Security team, and the Operations team. This is applicable to all type of users and roles such as System Administrators, Database Administrators, Network Engineers, and the Deployment and Tools teams. An SoD policy has been established for the various roles, and each production access request is validated to help ensure that SoD is not violated.

Developers do not have direct access to the production environment. The dev/test and production environments are segregated. As per SoD, all code pushes to production can only be done by members of the Cloud Operations team.

Access to SAP Ariba Buyer and Business Network Supplier Mobile Applications

For the buyer mobile application, access requires authorized permission, which allows for activation of the user's mobile device with their user account. Login requires the use of a password. A user may optionally use phone-provided PIN or biometrics to access the application.

For the business network supplier mobile application, login requires a valid username and password. A user may optionally use phone-provided biometrics to access the application.

Revocation of Access Rights

Employees and contractors who leave SAP (leavers) are first identified by systems (EC for internal employees and SAP FG for external contractors) via employee termination dates and contractor close dates. SAP FG via C-IDM and EC then interface the termination data to SAP IT IDM. SAP IT IDM synchronizes with SAP Global AD, which is then used by the Access Management tool. The Access Management tool automatically revokes the access rights of the leavers based on the data from SAP Global AD. The entire revocation process for this case is automated and is completed within a time frame of up to seven days.

Employees who change their job roles within SAP (changers) are first identified by EC via employee change dates. The employee changer data is then interfaced to SAP IT IDM. SAP IT IDM is then used by the Access Management tool. The Access Management Tool automatically revokes the access rights of the changers. The entire revocation process for this case is automated and is completed within a time frame of up to seven days.

Contractors are required to have a contractor end date field populated in SAP FG, which cannot be set to greater than 13 months from the account creation or extension date. Once the contractor end date is reached, or if the SAP FG account status is manually disabled, an automated workflow within SAP FG will trigger the user account deactivation process.

An automated script compares the Cloud Operations access management tool (Safeguard) with AD daily to identify user accounts with organization or cost center changes. Jira tickets are created by the script. Production credentials are deactivated within thirty business days, unless management confirms it is necessary for the employee to retain access.

At least quarterly, a review of all active employees and contractors within SAP IT IDM is completed. Any deviations from the process of the Deactivation of Users related to their expected inactivity are further assessed, activity logs are reviewed, and follow-up actions are taken. This process is documented.

Account Review

Every production user account within SAP Ariba and SAP Business Network is reviewed at least every six months to help ensure that permissions are still required for the job role of the individual user. Any unnecessary access identified is removed by the Site Reliability Engineering team.

Session Management

SAP Ariba and SAP Business Network solutions limit sessions to 30 minutes of idle time before timing out. Prior to a session timing out, the solutions send an alert to notify the idle user that their session is pending timeout, providing the user with an opportunity to intervene and cancel the timeout. If the user does not respond before the timeout period is reached, their work will be saved and they will be logged out of the system.

Keyshell Logging

Once a user logs onto the bastion host to access production, a keyshell script will capture user activity in keyshell logs to maintain an audit trail of actions. Access to keyshell logs is restricted to privileged sys admins.

Control Objective 5 – Invoice Payment Processing

Controls provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

The objective of the Invoice Payment Processing process is to provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

Data Validations

Data validations checks are done to help ensure data integrity for invoice payment processing. The Ariba Network validates invoices according to the buyer-configured rules and rejects invoices that do not pass validation, (e.g., the Ariba Network validates online invoices during data entry and displays onscreen messages for any errors that must be corrected).

Errors in Batch Payment

The application is configured to identify errors related to duplicate batch and unbalanced batch payments and provide notification to buyers when such errors occur.

Invoice Reconciliation Exception

An invoice exception is a discrepancy between the data on the invoice and the data on the associated order, contract, or receipt. Invoice exceptions can represent a variety of issues, such as missing receipts, mismatched quantities or prices, duplicate invoices, or tax variances. Exceptions can occur at either the line-item level or the header level of an invoice and require manual

intervention per the Invoice Exception configuration. User's group membership determines the invoice exceptions that the user can reconcile.

Supplier Bank Validation

Application is configured to validate the supplier bank account before payment is processed. Invalid supplier accounts are detected, blocked for payment, and the buyer is notified.

Customers can refer to guides available on SAP Help for further details on SAP Ariba Invoice Payment processing.

Various application controls noted above help ensure that transactions are flagged by the application right away for any inconsistencies so that such matters can be addressed, and transactions processed timely.

Complementary Subservice Organization Controls

In some instances, a service organization's controls cannot provide reasonable assurance that its control objectives were achieved without the subservice organizations performing certain activities in a defined manner. Such activities are referred to as complementary subservice organization controls (CSOCs). The following CSOCs are those controls that SAP's management assumed, in the design of the System, would be implemented by a subservice organization and are necessary, in combination with controls at SAP, to provide reasonable assurance that the service organization's control objectives are achieved.

Number	CSOC	Applicable Control Objective
Google LLC, SAP Cloud Infrastructure, and SAP Business Technology Platform		
1.	Responsible for establishing backup and recovery controls, including redundancy and encryption.	CO1
2.	Responsible for establishing procedures for the inventory of assets under their responsibility in order to record the required information throughout the asset lifecycle.	CO2
3.	Responsible for implementing technical safeguards to detect and respond to network-based attacks and for maintaining account and customer segregation.	CO3
4.	Responsible for implementing technical and organizational safeguards over access to systems components and such access is approved, created, maintained, reviewed, and terminated. Access to the production environment requires strong authentication mechanisms.	CO4
Google LLC and SAP Cloud Infrastructure		
5.	Responsible for technical and organizational safeguards for Change Management of system components of the cloud service, including segregation of duties, testing, and approval of changes.	CO2
6.	Responsible for encrypting the back up data at rest.	CO1

Number	CSOC	Applicable Control Objective
7.	Encryption keys are securely protected against modification and unauthorized disclosure. Confidentiality and integrity of the keys is supported by dedicated tools and processes.	CO4
8.	The hyperscaler is responsible for implementing physical security and environmental safeguards and controls for premises, buildings, and data centers. Additionally, the hyperscaler is responsible for controls over proper operation of their physical environments and data centers.	N/A*
SAP Cloud Infrastructure		
9.	Responsible for controls over the complete account lifecycle, from request to tracking and then removal, to support that the process is effective, controlled, and managed in line with governance standards and business demands.	CO2
10.	Responsible for controls for implementing technical and organizational safeguards to help ensure that access to systems components they are responsible for is approved, created, maintained, reviewed, and terminated. Access to production environment requires strong authentication mechanisms.	CO4
11.	Responsible for reviewing third party Infrastructure-as-a-Service provider attestation reports on regular basis including documentation of results and tracking of deviations as deemed critical.	N/A*
12.	Responsible for regularly assessing co-location data center provider, documenting results, tracking and communicating observations to management.	N/A*

* Note that this system description does not contain an associated control objective, as the subservice organizations are responsible for the related controls. Those controls are expected to be properly designed and operating effectively at the subservice organizations.

Complementary User Entity Controls

In some instances, a service organization's controls cannot provide reasonable assurance that its control objectives were achieved without user entities performing certain activities in a defined manner. Such activities are referred to as complementary user entity controls (CUECs). The following CUECs are those controls that SAP's management assumed, in the design of the System, would be implemented by user entities and are necessary, in combination with controls at SAP, to provide reasonable assurance that the service organization's control objectives are achieved.

Number	CUEC	Applicable Control Objective
1.	Customers are responsible for communicating with SAP Ariba and SAP Business Network regarding the timing and implementation of changes to their systems.	CO2

Number	CUEC	Applicable Control Objective
2.	Customers are responsible for configuring custom business rules for invoice processing reconciliation and validating the error-free operation of custom business rules when implemented.	CO5
3.	Customers are responsible for controls over managing their own access control systems on their infrastructure in regard to the use of the SAP Ariba Network Open adapter and any other document exchange adapters supported by SAP Ariba and SAP Business Network.	CO5
4.	Customers are responsible for controls over making additions, changes, or deletions to the authorization list for access to the SAP Ariba Network open adapter and any other document exchange adapters supported by SAP Ariba and SAP Business Network.	CO5
5.	Customers are responsible for maintaining their digital certificates as they apply to the use of the SAP Ariba and SAP Business Network solutions and adhering to the certificates' intended use.	CO4
6.	Customers are responsible for the proper configuration of their browser in order to interact with the SAP Ariba and SAP Business Network system supported by infrastructure managed by SAP.	CO4
7.	Customers are responsible for controls for assigning authorized users as organizational administrators for granting user access to the SAP Ariba and SAP Business Network system supported by infrastructure managed by SAP and optional features such as the SAP Ariba Mobile App.	CO4
8.	Customers are responsible for controls over configuring their SAP Ariba and SAP Business Network system supported by infrastructure managed by SAP user accounts and shared secrets such that passwords or PINs are sufficiently strong and properly managed.	CO4
9.	Customers are responsible for controls over their passwords and PINs are kept confidential.	CO4
10.	Customers are responsible for notifying SAP Ariba and SAP Business Network of possible security breaches or incidents using a web form.	CO4
11.	Customers are responsible for leveraging SSO authentication.	CO4
12.	Customers are responsible for performing periodic access reviews of their user's authorization to access the SAP Ariba and SAP Business Network solution.	CO4

**IV. SAP SE's Description of Its Control Objectives and
Related Controls, and Independent Service Auditor's
Tests of Controls and Results of Tests**

SAP SE's Description of Its Control Objectives and Related Controls, and Independent Service Auditor's Tests of Controls and Results of Tests

This report, when combined with an understanding of the controls at user entities, is intended to assist auditors in planning the audit of user entities' financial statements or user entities' internal control over financial reporting and in assessing control risk for assertions in user entities' financial statements that may be affected by controls at SAP. The examination was performed in accordance with attestation standards established by the AICPA, specifically, AT-C Section 320, *Reporting on an Examination of Controls at a Service Organization Relevant to User Entities' Internal Control Over Financial Reporting*, and the International Standard on Assurance Engagements 3402, *Assurance Reports on Controls at a Service Organization*, issued by the International Auditing and Assurance Standards Board.

Our examination was limited to the control objectives and related controls specified by SAP in Section IV of this report and did not encompass all aspects of the services provided or controls of SAP or extend to controls performed by user entities. Unique processes or control situations not included in the description are outside the scope of this examination.

It is the responsibility of each user entity and its independent auditor to evaluate this information in conjunction with the evaluation of internal control over financial reporting at the user entity in order to assess the total internal control. If internal control is not effective at user entities, SAP's controls may not compensate for such weaknesses.

The scope of the examination included tests of the operating effectiveness of controls over SAP's SAP Ariba and SAP Business Network System, including controls related to changes to the System applications, but did not include tests related to the functioning of or calculations performed by the software used in the delivery of the System or of reports generated by the software.

SAP's internal control represents the collective effect of various factors on establishing or enhancing the effectiveness of the controls specified by SAP. In planning the nature, timing, and extent of our testing of the controls to achieve the control objectives specified by SAP, we considered aspects of SAP's control environment, risk assessment process, monitoring activities, and information and communications.

Tests of Controls

Our testing of controls was restricted to the controls specified by SAP and was not extended to controls performed by user entities or other controls that were not documented as tested under each control objective listed in this section of the report.

The description of tests of controls and results of those tests are presented in this section of the report and are the responsibility of BDO USA, P.C., the service auditor. The description of the control objectives, the related controls, and the complementary subservice organization and user entity controls to achieve the objectives have been specified by, and are the responsibility of SAP.

The basis for all tests of operating effectiveness includes inquiry of the individual(s) responsible for the control. As part of our testing of each control, we inquired of the individual(s) to determine the fairness of the description of the control and to evaluate the design and implementation of the

control. As part of our inquiries, we also gained an understanding of the knowledge and experience of the personnel managing the control(s) and corroborated evidence obtained as part of other testing procedures. While inquiries were performed for every control, our inquiries were not listed individually for every control activity tested and shown in Section IV.

Additional testing of the control activities may have been performed using the following methods:

Method	Description
Inquiry	Inquired of appropriate personnel and corroborated responses with management.
Observation	Observed the application, performance, or existence of the specific control(s), as represented by management.
Inspection	Inspected documents and records indicating performance of the control.
Reperformance	Reperformed the control or processing application to ensure the accuracy of its operation.

When using information produced by the service organization, we evaluated whether the information was sufficiently reliable for our purposes by obtaining evidence about the accuracy and completeness of such information and evaluating whether the information was sufficiently precise and detailed for our purposes.

Control Objectives Summary

Control Objective Ref.	Control Objective	Control Objective Description
BR	Backup and Restore	Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up regularly and procedures are employed to maintain the integrity of the data backup.
CM	Change Management	Controls provide reasonable assurance that changes to the production environment relevant to user entities' internal control over financial reporting are authorized, tested, documented, approved, and implemented.
NC	Network and Communication Management	Controls provide reasonable assurance that network infrastructure relevant to user entities' internal control over financial reporting is configured to result in valid, complete, and accurate processing and reporting and to protect data from unauthorized changes.
UAM	User and Access Management	Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.
IPP	Invoice Payment Processing	Controls provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

Control Objective 1 – Backup and Restore

Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up regularly and procedures are employed to maintain the integrity of the data backup.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
BR.B	Backups are performed at planned intervals for backup relevant production systems in accordance with documented procedures.	Inspected the backup configurations for in-scope production systems to determine whether backups were performed at planned intervals in accordance with documented procedures.	No exceptions noted.
		Inspected the selected backup logs for the in-scope production systems to determine whether backups were performed in accordance with documented procedures.	No exceptions noted.
BR.C	Backup jobs are monitored and repeated failed jobs are followed-up for correction.	Inspected the configuration of alerts to determine whether alerts were configured to monitor backups for failures.	No exceptions noted.
		Inspected the related tickets for a selection of backup failure alerts to determine whether the alerts were remediated and resolved.	No exceptions noted.
BR.G	Data restoration functionality testing is completed to verify the usability of backup data. The testing procedures and results are documented.	Inspected Jira tickets for a selection of data restoration requests to determine whether data restoration functionality testing was completed to verify the usability of backup data and results was documented.	No exceptions noted.
BR03_Ariba	To help ensure the durability, the backup data is transmitted through encrypted communication channel to a remote site.	Inspected the encryption configurations for in-scope production systems to determine whether the backup data was transmitted through encrypted communication channel to a remote site, to help ensure durability.	No exceptions noted.

Control Objective 2 – Change Management

Controls provide reasonable assurance that changes to the production environment relevant to user entities' internal control over financial reporting are authorized, tested, documented, approved, and implemented.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
5.01_ Ariba	The documented systems development methodology describes the change initiation, software development, change documentation, and approval processes.	Inspected Ariba's PLM document for product development to determine whether the documented systems development methodology described the change initiation, software development, change documentation, and approval processes.	No exceptions noted.
5.08_ Ariba	Development and test environments are segregated from production.	Observed an administrator establish network connections to a production server as well as development and test environments to determine whether these environments were segregated from production.	No exceptions noted.
5.09_ Ariba	GitHub is utilized to maintain the production code base. It incorporates code review functionalities to ensure that source code changes made by developers undergo review before being merged into the main branches.	Inspected the branch protection settings for the in-scope repositories to determine whether GitHub was utilized to maintain the production code base and source code changes made by developers underwent review before being merged into the main branches.	No exceptions noted.
		Observed a change request in GitHub that had not yet been approved to determine whether the system was configured to prevent the changes without the approval from being merged.	No exceptions noted.
AM01_ Ariba	Production assets are identified in an asset inventory. Key attribute data for virtual assets is recorded.	Observed the asset inventory management system to determine whether the key attribute fields were recorded.	No exceptions noted.

Control Objective 2 – Change Management

Controls provide reasonable assurance that changes to the production environment relevant to user entities' internal control over financial reporting are authorized, tested, documented, approved, and implemented.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the monthly asset reconciliation meeting minutes for a selection of months to determine whether the asset listing was reviewed for completeness.	No exceptions noted.
CM02_Ariba	Infrastructure changes are handled in accordance with SAP Ariba's change management procedures. Changes are requested, approved prior to implementation and include change plan, rollback plan, and test plan (where applicable). Standard and emergency changes are approved by an individual other than the requestor.	Inspected the change tickets for a selection of infrastructure changes to determine whether the infrastructure changes were handled in accordance with SAP Ariba's Change Management procedures and changes were requested, approved prior to implementation, and included change plan, rollback plan, and test plan (where applicable); and that standard and emergency changes were approved by an individual other than the requestor.	No exceptions noted.
CM03a_Ariba	Standard application changes are tested and approved prior to deployment. Changes are approved by an individual other than the requestor. Emergency changes follow the standard change management process but approval may be documented after the change is implemented. Documentation for externally facing features is provided as the features become generally available to customers.	Inspected the change tickets for a selection of standard and emergency software changes to determine whether changes were tested and approved prior to deployment and changes were approved by an individual other than the requestor.	No exceptions noted.
		Inspected the Ariba Release Portal to determine whether documentation for externally facing features was provided as the features became generally available to customers.	No exceptions noted.

Control Objective 2 – Change Management

Controls provide reasonable assurance that changes to the production environment relevant to user entities' internal control over financial reporting are authorized, tested, documented, approved, and implemented.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
CM03b_Ariba	SAP Business Network Supplier mobile app is tested and approved prior to deployment. Changes are approved by an individual other than the requestor. Documentation for externally facing features is provided as the features become generally available to customers.	Inspected the mobile app release version history for mobile application changes and inquired of management and determined that there were no mobile app changes or releases for the examination period.	The circumstances that warrant the operation of this control did not occur during the examination period, and as a result, the operating effectiveness of this control could not be tested.
CM03c_Ariba	SAP Ariba Procurement mobile app is tested and approved prior to deployment. Changes are approved by an individual other than the requestor. Documentation for externally facing features is provided as the features become generally available to customers.	Inspected the change tickets for a selection of mobile application changes to determine whether the SAP Ariba Procurement mobile app was tested and approved prior to deployment and the changes were approved by an individual other than the requestor.	No exceptions noted.
		Inspected the mobile application release portal to determine whether documentation for externally facing features was provided as the features became generally available to customers.	No exceptions noted.
NWS04	Changes of firewall rules are approved, logged, and can be traced back to the user performing the change.	Inspected the change tickets for a selection of firewall rule changes to determine whether changes to firewall rules were approved, logged, authorized, and could be traced back to the user performing the change.	No exceptions noted.

Control Objective 3 – Network and Communication Management

Controls provide reasonable assurance that network infrastructure relevant to user entities' internal control over financial reporting is configured to result in valid, complete, and accurate processing and reporting and to protect data from unauthorized changes.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
NWS05	Firewall rule sets are reviewed on a quarterly basis.	Inspected the firewall review tickets for a selection of quarters to determine whether firewall rulesets were reviewed on a quarterly basis.	No exceptions noted.
NWS23	Network diagrams for the production environment have been documented and are reviewed at least annually. Network diagrams include the design of separate security zones.	Inspected the network architecture diagrams and review to determine whether network diagrams for the production environment were documented and reviewed annually and included the design of separate security zones.	No exceptions noted.
NWS30_ Ariba	Intrusion detection/prevention tools are configured to scan and block network threats for vulnerabilities, malware, and spyware.	Inspected the IDS/IPS configurations to determine whether IDS/IPS tools were configured to block network threats for vulnerabilities, malware, and spyware.	No exceptions noted.
NWS31_ Ariba	Ariba uses, at a minimum, 128-bit TLS encryption for transmission of private or confidential information over public networks.	Inspected the encryption details for a selection of public-facing websites to determine whether Ariba uses, at a minimum, 128-bit TLS encryption for transmission of private or confidential data over public networks.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.01_ Ariba	Formal user access management procedures have been documented and made available to relevant administrative users.	Inspected the SAP Ariba Cloud Ops – Production Access Request document available on Ariba Confluence to determine whether formal user access management procedures were documented and made available to administrative users.	No exceptions noted.
UAM01_ SCO_B	Access authorisations are requested and documented in a ticketing tool. Each access request is assessed by authorized approvers.	Inspected the access request tickets for a selection of users added to production systems to determine whether access authorisations were requested and documented in a ticketing tool and each access request was approved by an authorized user, other than the submitter.	No exceptions noted.
2.03_ Ariba	System Access procedures are documented that define access control requirements for restricting access to the least privilege necessary for privileged users to perform job responsibilities and maintain segregation of duties for production access.	Inspected the Cloud Ops – Segregation of Duties and Safeguard Access – Roles Definition policies to determine whether requirements for segregation of duties were defined and documented.	No exceptions noted.
		Inspected the system generated list of user accounts for the development team and the production team, their associated job titles, and inquired of management to determine whether users are appropriate, and that segregation of duties is maintained between the development team and the production team.	No exceptions noted.
2.05_ Ariba	SAP Ariba's password settings are configured in accordance with the SAP Global Security Standard.	Inspected the SAP Global Security Standard for Accounts and Passwords to determine whether password requirements were defined.	No exceptions noted.

Solely for the information and use of SAP SE, user entities of SAP SE's SAP Ariba and SAP Business Network System during some or all of the period April 1, 2024 to September 30, 2024, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the system password settings to determine whether passwords were configured in accordance with the SAP Global Security Standard.	No exceptions noted.
2.06_ Ariba	The ability to login, via shell or command line to production servers is restricted to authorized personnel by a Bastion Host using two-factor authentication.	Inspected the Pluggable Authentication Module configuration to determine whether two-factor authentication is in place.	No exceptions noted.
		Observed a system administrator traverse the authentication points required to gain logical access to the production network to determine whether the user is required to authenticate via a bastion host and that two-factor authentication was required.	No exceptions noted.
2.07_ Ariba	Keyshell logging is in place to provide an audit trail of actions performed while logged into the production environment via the Bastion Host.	Inspected a system output of accounts that are not configured with keyshell logging to determine whether there were any user accounts that were identified.	Exception noted. One user account was identified in the system output of accounts that was not configured with keyshell logging.
		Observed a system administrator run a key-capture command to determine whether user input was captured and logged to provide an audit trail of actions performed.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the system generated list of individuals with the ability to view or modify keyshell log permissions, their associated job titles, and inquired of management to determine whether it was limited to appropriate personnel.	No exceptions noted.
2.10_ Ariba	Customer access to hosted applications requires a unique username and a password. The applications enforce an expiration date on the password of 90 days, and a password history to prevent the re-use of the last six passwords. Furthermore, the account is locked after five invalid password logon attempts.	Inspected the password configurations on the Business Network to determine whether the application enforced expiration date of 90 days, password history to prevent re-use of the last six passwords, and account lockout after five invalid password logon attempts.	No exceptions noted.
		Observed a system administrator attempt to re-use a previous password and input incorrect passwords on the Business Network to determine whether the application enforced password history to prevent re-use of the last six passwords and account lockout after five invalid password logon attempts.	No exceptions noted.
		Observed a system administrator attempt to create a customer account that already existed on the Business Network to determine whether the system prevented the use of a non-unique username.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
2.11_ Ariba	Customer access is segregated such that users may only view or access their own assigned data which is linked to their organizational and user ID.	Inspected the database schema to determine whether users and data objects were associated with a unique identifier.	No exceptions noted.
		Observed a Senior Quality Specialist perform a successful and a failed attempt to view customer data to determine whether customer access was segregated such that users may only view or access their own assigned data, which is linked to their organizational and user ID.	No exceptions noted.
2.12_ Ariba	SAP Business Network Supplier Mobile App is configured to authenticate users with a unique user account and enforce predefined password requirements.	Inspected the SAP Business Network Supplier Mobile App password configurations to determine whether the application was configured to authenticate users with a unique user ID and enforced predefined password requirements.	No exceptions noted.
HR05	External workers are provisioned access within the backend of Fieldglass for a maximum of 13 months. There is an automatic check in the backend which prevents an external worker from retaining access for longer than 13 months. If the user was provisioned at the front end of Fieldglass for longer than 13 months, the backend will flag an error and the error message will be updated in the Fieldglass system in Buyer Reference Field.	Inspected the external worker configuration to determine whether a worker end date is required and cannot be set to greater than 13 months from the account creation or extension date.	No exceptions noted.
		Observed a user update the worker end date for an external worker to determine whether a worker end date is required and an exception message occurs when the worker end date field is beyond 13 months	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Observed a selected external worker log to determine whether the Fieldglass system deactivates a user once the worker end date is reached.	No exceptions noted.
HR09	On a daily basis an end of employment pending workflow report is run from SuccessMap End of Employment. If any pending workflows are identified upon manual review with retroactive effective dates an "Instant Access Removal" is populated in Employee Central to trigger access removal by IDM.	Inspected the analysis for a selection of days to determine whether an end of employment pending workflow report is run from SuccessMap End of Employment and, as appropriate, action is taken.	No exceptions noted.
UAM04_External_Leaver	The logical access rights of external workers leaving SAP are revoked within 7 days after the change taking effect.	Inspected the automated scripts and system logs to determine whether SAP has an automated process for adjusting access rights.	No exceptions noted.
		Inspected system lock dates for a selection of terminated external workers to determine whether access was revoked within seven days after the change taking effect.	No exceptions noted.
UAM04_Internal_Changer	The logical access rights of internal employees changing job roles within SAP are revoked within 7 days after the change taking effect.	Inspected the automated scripts and system logs to determine whether SAP has an automated process for adjusting access rights.	No exceptions noted.
		Inspected system lock dates for a selection of internal employees changing job roles to determine whether access was revoked within seven days after the change taking effect.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
UAM04_ Internal _Leaver	The logical access rights of internal employees leaving SAP are revoked within 7 days after the change taking effect.	Inspected the automated scripts and system logs to determine whether SAP has an automated process for adjusting access rights.	No exceptions noted.
		Inspected system lock dates for a selection of internal employees leaving SAP to determine whether access was revoked within seven days after the change taking effect.	No exceptions noted.
UAM04_ PIT	A point-in-time quarterly review of all active internal employees and external workers SAP IT Identity Management (IDM) accounts is completed. Active IDM accounts identified without an associated active HR (Employee Central/Fieldglass) record are further assessed for post-termination login activity to the production environment. For any employees and external workers who are identified as having post-termination login activity to the production environment, their activity logs are reviewed for inappropriate events.	Inspected SAP's detailed point-in-time analysis of access revocation for a selection of quarters to determine whether a review of all active IDM accounts is completed and, as appropriate, action is taken.	No exceptions noted.
UAM04a _Ariba	Production credentials are removed within seven business days after a user has been identified as a terminated employee.	Inspected the SAP Global Active Directory automation compare check job used to compare SAP Global Active Directory with SAP Ariba's Safeguard (production access) to determine whether it is configured to automatically identify terminated users and generate access removal tickets.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the access removal tickets for a selection of terminated users to determine whether production access is removed within seven business days of their termination date.	No exceptions noted.
UAM04b_Ariba	For employees who transfer between roles (i.e., organizational or cost center change), production credentials are deactivated within thirty business days, unless management confirms it is necessary for the employee to retain access.	Inspected the SAP Global Active Directory automated compare check job used to compare SAP Global Active Directory with SAP Ariba's Safeguard (production access) to determine whether it is configured to automatically identify employees who transfer roles and generate access confirmation or modification tickets.	No exceptions noted.
		Inspected the access removal tickets for a selection of transferred employees to determine whether manager approval is obtained for access retention, or production access is removed within 30 business days.	No exceptions noted.
UAM11_SCO	Access authorisations are assigned with validity of defined timeline. If no automated functionality is in place or profiles not assigned a validity of up to 6 months, access authorisations of users are reviewed by an authorized person at least every 6 months. The result of the review is documented and unnecessary authorisations are removed.	Inspected the master access review tickets for the examination period, for users where no automated functionality is in place or profiles are not assigned a validity of up to six months, to determine whether review of the users by authorized people is initiated.	No exceptions noted.

Control Objective 4 – User and Access Management

Controls provide reasonable assurance that logical access to production systems and data files relevant to user entities' internal control over financial reporting is restricted to authorized users.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
		Inspected the user access review tickets for a selection of users to determine whether a review is performed by an authorized person at least every six months, the result of the review is documented, and unnecessary authorization is removed.	No exceptions noted.

Control Objective 5 – Invoice Payment Processing

Controls provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
8.01_ Ariba	Data entry screens for manual invoices entry contain mandatory fields and edit/validation checks to enforce completeness of inputs.	Inspected the Ariba Network application configuration logic to determine whether mandatory fields are enforced within the system.	No exceptions noted.
		Observed application demonstration of the Ariba Network to determine whether data entry screens for invoice manual entry contained required fields and edit/validation checks to enforce completeness of inputs.	No exceptions noted.
8.03_ Ariba	Duplicate payment batches received from buyers are identified and ignored and the buyer is notified.	Inspected the Ariba Network application configuration logic to determine whether duplicate payment batches created were flagged as exceptions within the Ariba Network application.	No exceptions noted.
		Observed the process owner attempt to submit a duplicate batch to determine whether the batch was placed in an error queue and the buyer was notified.	No exceptions noted.
		Observed the process owner attempt to submit a payment batch with balanced payment amounts and inspected the corresponding payment details log entry for the payment batch to determine whether batch was processed successfully with a “transmitted” status.	No exceptions noted.

Control Objective 5 – Invoice Payment Processing

Controls provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
8.04_ Ariba	Payment batch aggregate amounts not in balance are identified, errored out, and the buyer is notified.	Inspected the configuration code logic to determine whether the system was configured to flag any mismatch in the payment batch aggregate amounts and notify the user of the mismatch.	No exceptions noted.
		Observed the process owner attempt to submit a batch with balanced payment amounts to determine whether the batch was processed successfully.	No exceptions noted.
		Observed the process owner attempt to submit a batch with unbalanced payment amounts to determine whether the payment batch was placed in an error queue and the system notified the buyer.	No exceptions noted.
8.06_ Ariba	Invoice reconciliation exceptions are identified in accordance with customer specified business processes and require manual intervention when tolerances are exceeded.	Inspected the code logic to determine whether the Ariba system was configured to trigger an exception based upon the values to be checked during invoice reconciliation.	No exceptions noted.
		Observed the process owner attempt to submit an Ariba Network invoice in violation of the exceptions, for a selection of header and line-level exceptions, to determine whether the exception was flagged in the Ariba invoice system.	No exceptions noted.

Control Objective 5 – Invoice Payment Processing

Controls provide reasonable assurance that invoice and payment transactions are processed completely, accurately, and in a timely manner.

Control Number	Controls Specified by SAP SE	Tests of Controls Performed by BDO USA, P.C.	Results of Tests
8.07_ Ariba	Supplier accounts are validated based on their proxy ID prior to a payment being processed. Invalid supplier accounts are detected, blocked for payment, and the buyer is notified.	Inspected the configuration code logic to determine whether supplier accounts were verified against their IDs.	No exceptions noted.
		Observed the process owner attempt to submit an Ariba Network payment remittance file with invalid supplier information to determine whether the Ariba Network application identified the error, blocked the payment, and notified the buyer.	No exceptions noted.
		Observed the process owner attempt to submit an Ariba Network payment remittance file with valid supplier information to determine whether it was processed successfully.	No exceptions noted.

**V. Other Information Provided by SAP SE
That Is Not Covered by the Independent Service
Auditor's Report on a SOC 1 Examination**

Other Information Provided by SAP SE That Is Not Covered by the Independent Service Auditor's Report on a SOC 1 Examination

Management Responses to Exceptions Noted

Control Number	Controls Specified by SAP SE	Results of Tests	Management Response
2.07_Ariba	Keyshell logging is in place to provide an audit trail of actions performed while logged into the production environment via the Bastion Host.	Exception noted. One user account was identified in the system output of accounts that was not configured with keyshell logging.	The one user account where keyshell logs weren't enabled was a temporary account created by Google agent while bastion host server was down on August 19, 2024. It was required to restore services on the bastion host. Compensating control on RSA two factor authentication (2.06) denies access to any user without valid RSA token, which was the case with the temporary account. The temporary account has been removed. Please note keyshell logging cannot be enabled on such temporary accounts, however, based on analysis of GCP console and server logs, the access was appropriate and no suspicious activities were performed.

Changes to Controls from Previous Report

The following changes in SAP's control set were made compared to the previous report:

Change Type	Process	Affected Control(s)	Remark	Valid To	Valid From
Modification	Backup and Restore	BR.B	Control ID was renamed from BR01 to BR.B.	BR01: Valid to 2024-03-31	BR.B: Valid from 2024-04-01
Modification	Backup and Restore	BR.C	Control ID was renamed from BR02 to BR.C and control description was simplified.	BR02: Valid to 2024-03-31	BR.C: Valid from 2024-04-01
Removal	Backup and Restore	BR04	Control was removed from SOC1 scope		
Removal	Backup and Restore	BR05	Control BR05 was merged with BR.G.	BR05: Valid to 2024-03-31	

Change Type	Process	Affected Control(s)	Remark	Valid To	Valid From
Modification	Backup and Restore	BR.G	Control ID was renamed from BR06 to BR.G.	BR06: Valid to 2024-03-31	BR.G: Valid from 2024-04-01
Removal	User and Access Management	UAM04_Changers_Impact	Control was removed as process implementation was improved.	UAM04_Changers_Impact: Valid to 2024-03-31	
Removal	User and Access Management	UAM04_Term_Impact	Control was removed as process implementation was improved.	UAM04_Term_Impact: Valid to 2024-03-31	
Modification	User and Access Management	UAM04_Internal_Leaver_Changer	UAM04_Internal_Leaver_Changer was split into UAM04_Internal_Leaver and UAM04_Internal_Changer, and the language was updated to reflect the updated process.	UAM04_Internal_Leaver_Changer: Valid to 2024-03-31	UAM04_Internal_Leaver and UAM04_Internal_Changer: Valid from 2024-04-01
Modification	User and Access Management	UAM01_SCO_B	Control ID was renamed from 2.02_Ariba to UAM01_SCO_B and control description was simplified.	2.02_Ariba: Valid to 2024-03-31	UAM01_SCO_B: Valid from 2024-04-01
Modification	Secure Software Development	5.09_Ariba	Control description was simplified.		Valid from 2024-04-01
Modification	User and Access Management	UAM04_External_Leaver	Control description was updated to reflect all relevant logical access rights to systems in-scope, impacting the revocation timeframe.		Valid from 2024-04-01
Modification	User and Access Management	UAM11_SCO	Control description was simplified.	UAM11_SCO Valid to 2024-03-31	UAM11_SCO: Valid from 2024-04-01
Removal	User and Access Management	AS_AMON4, AS_AMON5, AS_AMON6a, AS_AMON6b, AS_AMON7	Control was removed from SOC1 scope		
Modification	Change Management	AM01_Ariba	Control description was simplified		Valid from 2024-04-01

Solely for the information and use of SAP SE, user entities of SAP SE's SAP Ariba and SAP Business Network System during some or all of the period April 1, 2024 to September 30, 2024, and their auditors who audit and report on user entities' financial statements or internal control over financial reporting and have a sufficient understanding of it.